

รายงาน

การออกแบบและรักษาความปลอดภัยเครือข่าย

สำหรับเว็บไซต์ WordPress บน VPS

จัดทำโดยกลุ่ม BetterSon

เนติธร พุ่มพวง รหัสนิสิต 67160071

คราม พลับสกุล รหัสนิสิต 67160417

สิรวัชร์ ชณาธิศากูล รหัสนิสิต 67160430

เสนอ

ผศ.ภูสิต กุลเกษม

รายงานนี้เป็นส่วนหนึ่งของรายวิชา

88633065 Computer Networks

ชั้นปีที่ 3 ภาคเรียนที่ 1 ปีการศึกษา 2569

จัดทำวันที่ 30 ตุลาคม พ.ศ. 2569

คณะวิทยาการสารสนเทศ

มหาวิทยาลัยบูรพา

คำนำ

รายงานฉบับนี้จัดทำขึ้นเพื่อศึกษาการนำความรู้ด้านเครือข่ายคอมพิวเตอร์มาใช้ติดตั้งและดูแลเว็บไซต์ WordPress บนเครื่องแม่ข่ายเสมือน โดยเน้นการออกแบบเส้นทางการสื่อสาร การควบคุมการเข้าถึง และการรักษาความปลอดภัยหลายชั้น เพื่อให้เห็นความสัมพันธ์ระหว่างบริการบนอินเทอร์เน็ตกับมาตรการป้องกันในแต่ละระดับ

เนื้อหาประกอบด้วยหลักการด้านเครือข่าย การออกแบบระบบบน AWS การใช้ DNS และ HTTPS การกำหนด Firewall การบริหารผ่าน Tailscale การติดตามสถานะ การสำรองข้อมูล และผลทดสอบของกลุ่ม พร้อมอภิปรายข้อจำกัดและแนวทางพัฒนาระบบต่อไป

ผู้จัดทำหวังว่ารายงานฉบับนี้จะช่วยให้ผู้อ่านเข้าใจการประยุกต์ใช้แนวคิดด้านเครือข่ายและความปลอดภัยกับระบบเว็บไซต์ และสามารถใช้เป็นแนวทางในการวางแผนทดสอบและปรับปรุงระบบต่อไป

คณะผู้จัดทำ

30 ตุลาคม 2569

บทคัดย่อ

โครงงานนี้ศึกษาการออกแบบเครือข่ายและการรักษาความปลอดภัยสำหรับเว็บไซต์ WordPress บน VPS ของ AWS โดยใช้ DuckDNS สำหรับชื่อโดเมน nginx เป็นเว็บเซิร์ฟเวอร์ PHP-FPM ประมวลผลโปรแกรม และ MySQL จัดเก็บข้อมูล เป้าหมายคือให้บริการเว็บไซต์ผ่าน HTTPS จำกัดการเข้าถึงเว็บไซต์ตามประเทศต้นทาง และแยกช่องทางดูแลระบบออกจากอินเทอร์เน็ตสาธารณะ

ระบบใช้ AWS Security Group ร่วมกับ nftables เพื่อควบคุมการเชื่อมต่อ ใช้กุญแจ SSH สำหรับยืนยันตัวตน และให้ผู้ดูแลเข้าถึง SSH ผ่าน Tailscale นอกจากนี้มีการลดคำขอซ้ำด้วย FastCGI cache จำกัดความถี่การเข้าสู่ระบบ ตรวจติดตาม Log และใช้ระบบแจ้งเตือนเมื่อบริการหยุดทำงาน

กลุ่มทดสอบแล้วพบว่า SSH ผ่าน Tailscale ใช้งานได้ ส่วน SSH ผ่าน IP สาธารณะหมดเวลารอ เว็บไซต์ใช้งานผ่าน HTTPS และต่ออายุจำลองด้วย Certbot ผ่าน ผล ApacheBench จำนวน 200 คำขอ ที่ concurrency 10 ภายในเซิร์ฟเวอร์ ให้ throughput 548.30 คำขอต่อวินาที เมื่อใช้ cache เทียบกับ 19.96 เมื่อ BYPASS หรือเพิ่มประมาณ 27.47 เท่า กลุ่มทดสอบการแบน Honeypot การแจ้งเตือน Telegram และการกู้คืนบริการได้ตามที่ออกแบบ ส่วน IPv6 และการกู้คืนข้อมูลสำรองเป็นแนวทางทดสอบเพิ่มเติม

คำสำคัญ เครือข่ายคอมพิวเตอร์ VPS Firewall HTTPS Tailscale WordPress

สารบัญ

เรื่อง	หน้า
คำนำ	ก
บทคัดย่อ	ข
สารบัญ	ค
บทที่ 1 บทนำ	1
บทที่ 2 ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง	3
บทที่ 3 การออกแบบและดำเนินงาน	5
บทที่ 4 ผลการดำเนินงานและการทดสอบ	15
บทที่ 5 สรุปผลและข้อเสนอแนะ	25
บรรณานุกรม	27
ภาคผนวก ก คู่มือคำสั่งและการทดสอบระบบ	29
ภาคผนวก ข รายการหลักฐานประกอบ	36
ภาคผนวก ค ภาพประกอบเส้นทางการสื่อสาร	37
ภาคผนวก ง แนวคำตอบประกอบการนำเสนอ	40
ภาคผนวก จ ภาพหลักฐานประกอบการทดสอบ	42

บทที่ 1
บทนำ

1.1 ความเป็นมาและความสำคัญ

เว็บไซต์ที่เปิดให้บริการบนอินเทอร์เน็ตต้องรับการเชื่อมต่อจากเครือข่ายภายนอก จึงมีความเสี่ยงจากการสแกนพอร์ต การเดารหัสผ่าน การค้นหาไฟล์สำคัญ และการใช้ช่องโหว่ของซอฟต์แวร์ การติดตั้งเว็บไซต์ให้ใช้งานได้เพียงอย่างเดียวจึงไม่เพียงพอ ผู้ดูแลต้องกำหนดว่าบริการใดเปิดให้ใครเข้าถึงได้ และตรวจสอบสิ่งที่เกิดขึ้นหลังเปิดใช้งาน

โครงงานนี้ใช้เว็บไซต์แนะนำหลักสูตรวิทยาการคอมพิวเตอร์เป็นกรณีศึกษา โดยติดตั้ง WordPress บน AWS EC2 และออกแบบให้ผู้ใช้ทั่วไปเข้าถึงเว็บไซต์ผ่าน HTTPS ส่วนผู้ดูแลใช้เครือข่ายส่วนตัว Tailscale สำหรับ SSH แนวทางดังกล่าวเชื่อมโยงองค์ความรู้ด้าน IP address พอร์ต โปรโตคอล DNS การเข้ารหัส และ Firewall เข้ากับระบบใช้งานจริง

1.2 วัตถุประสงค์

1. ศึกษาเส้นทางการสื่อสารระหว่างผู้ใช้ เว็บเซิร์ฟเวอร์ และฐานข้อมูล
2. ออกแบบการเข้าถึงเว็บไซต์ผ่าน HTTPS และจำกัดการเข้าถึงตามเครือข่ายต้นทาง
3. ลดการเปิดเผยบริการดูแลระบบ โดยใช้ SSH ด้วยกุญแจผ่าน Tailscale
4. ศึกษาการเพิ่มประสิทธิภาพ การติดตามสถานะ และการกู้คืนบริการ
5. จัดทำผลทดสอบและหลักฐานที่ตรวจสอบย้อนกลับได้

บทที่ 1 บทนำ ต่อ

1.3 ขอบเขตของโครงงาน

ระบบประกอบด้วยเครื่องแม่ข่าย AWS EC2 หนึ่งเครื่อง ระบบปฏิบัติการ Ubuntu เว็บเซิร์ฟเวอร์ nginx PHP-FPM WordPress และ MySQL ใช้ชื่อโดเมน betterson.duckdns.org มาตรการด้านเครือข่ายครอบคลุม AWS Security Group, nftables, HTTPS และ Tailscale ส่วนการดูแลระบบครอบคลุมการบันทึกเหตุการณ์ การสำรองข้อมูล และการแจ้งเตือนผ่าน Telegram

การจำกัดประเทศใช้รายการเครือข่าย IPv4 ของประเทศไทยตามข้อมูลผู้ให้บริการรายการ IP จึงเป็นการจำแนกตามตำแหน่งของ IP ไม่ใช่การตรวจสอบสัญชาติผู้ใช้ การประเมินไม่ครอบคลุมการทดสอบเจาะระบบเต็มรูปแบบหรือการรับมือ DDoS ขนาดใหญ่

1.4 วิธีดำเนินงาน

เริ่มจากวิเคราะห์ข้อกำหนดและแบ่งช่องทางใช้งาน จากนั้นติดตั้งบริการเว็บ กำหนด DNS และใบรับรอง TLS ตั้งค่าการเข้าถึงระดับเครือข่ายและระดับโปรแกรม แล้วจึงเพิ่ม cache การติดตามสถานะ และการสำรองข้อมูล ขั้นสุดท้ายทดสอบตามกรณีใช้งานและรวบรวมหลักฐานเพื่อเปรียบเทียบผลที่คาดหวังกับผลที่พบ

1.5 ประโยชน์ที่คาดว่าจะได้รับ

ผู้จัดทำสามารถอธิบายบทบาทของบริการและมาตรการแต่ละชั้น วางแผนเปิดพอร์ตตามความจำเป็น และตรวจสอบปัญหาจากหลักฐานได้อย่างเป็นระบบ อีกทั้งเข้าใจข้อแลกเปลี่ยนระหว่างความปลอดภัย ความสะดวกในการใช้งาน และทรัพยากรเครื่องแม่ข่าย

บทที่ 2
ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง

2.1 แบบจำลองการสื่อสารและโปรโตคอล

ในมุมมอง TCP/IP เว็บใช้ HTTP ในระดับ Application โดย HTTPS เพิ่มการปกป้องด้วย TLS การเชื่อมต่อเว็บในโครงงานนี้ใช้ TCP/IP เป็นพื้นฐาน ส่วนการระบุหมายเลขพอร์ตช่วยให้เครื่องแม่ข่ายแยกบริการได้ เช่น TCP 443 สำหรับ HTTPS และ TCP 22 สำหรับ SSH การควบคุมที่พอร์ตต้องพิจารณาร่วมกับ IP ต้นทางและช่องทางที่แพ็กเก็ตเข้ามา

2.2 DNS และ HTTPS

DNS แปลงชื่อโดเมนเป็น IP address ก่อนที่ผู้ใช้จะเริ่มเชื่อมต่อกับเครื่องแม่ข่าย จึงเป็นขั้นตอนค้นหาปลายทาง ไม่ใช่อุปกรณ์ที่รับส่ง HTTP ทุกคำขอ DuckDNS ช่วยให้ใช้ชื่อโดเมนกับ IP ของระบบได้ ส่วน HTTPS ใช้ใบรับรองดิจิทัลประกอบการยืนยันชื่อเว็บไซต์และเข้ารหัสข้อมูลระหว่างเบราว์เซอร์กับเว็บเซิร์ฟเวอร์

DNS-01 เป็นวิธีพิสูจน์สิทธิ์ควบคุมโดเมนด้วยระเบียน TXT สำหรับออกใบรับรอง จึงเหมาะกับระบบที่จำกัดการเข้าถึงเว็บจากภายนอก การต่ออายุอัตโนมัติต้องมีการอัปเดตระเบียน DNS ผ่านกลไกที่ทำงานโดยไม่ต้องกรอกด้วยตนเอง และต้องปกป้องข้อมูลรับรองของบริการ DNS [1]

2.3 Firewall แบบมีสถานะ

Firewall ควบคุมการรับส่งข้อมูลตามกฎ AWS Security Group เป็นตัวควบคุมระดับโครงสร้างพื้นฐานและมีการติดตามสถานะการเชื่อมต่อ ส่วน nftables ทำงานบนระบบ Linux และกำหนดกฎให้สัมพันธ์กับบริการในเครื่องได้ การใช้หลายชั้นช่วยลดผลกระทบจากการตั้งค่าผิดชั้นเดียว แต่ทุกชั้นยังต้องตรวจสอบร่วมกัน [2], [3]

บทที่ 2 ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง ต่อ

2.4 SSH และเครือข่ายส่วนตัว Tailscale

SSH ใช้บริหารเครื่องจากระยะไกล การยืนยันตัวตนด้วยกุญแจช่วยลดการพึ่งพารหัสผ่านบัญชีบนเซิร์ฟเวอร์ ส่วน passphrase ใช้ป้องกันกุญแจส่วนตัวบนเครื่องผู้ดูแล การใช้ Tailscale เพิ่มเครือข่ายส่วนตัวระหว่างอุปกรณ์ที่ได้รับอนุญาต โดยอาจเชื่อมต่อโดยตรงหรือผ่านตัวกลาง DERP ตามสภาพเครือข่าย [4]

โครงงานนี้ใช้ OpenSSH ผ่านเครือข่าย Tailscale ซึ่งแยกจากคุณสมบัติ Tailscale SSH การเข้าสู่ระบบยังตรวจสอบกุญแจด้วย OpenSSH ตามเดิม สิทธิ์เข้าถึงใน tailnet ควรจำกัดเฉพาะอุปกรณ์และผู้ดูแลที่จำเป็น การยืนยันตัวตนของบัญชีผู้ให้บริการและ 2FA เกี่ยวข้องกับการเข้าร่วมและจัดการบัญชี ไม่ได้หมายความว่ามีการถาม 2FA ใหม่ทุกครั้งที่ SSH

2.5 การป้องกันหลายชั้นและสิทธิ์เท่าที่จำเป็น

แนวคิด Defense in Depth ใช้มาตรการหลายระดับ เช่น ปิดพอร์ตที่ไม่จำเป็น ใช้กุญแจจำกัดความถี่คำขอ และตรวจ Log ส่วน Least Privilege ให้บัญชีหรือบริการได้รับสิทธิ์เท่าที่ต้องใช้ ตัวอย่างคือให้บัญชีฐานข้อมูลเข้าถึงเฉพาะฐานข้อมูลของ WordPress และไม่เปิด MySQL สู่อินเทอร์เน็ต แนวทางปรับปรุง WordPress ต้องครอบคลุมทั้งสิทธิ์ไฟล์ การอัปเดต และการจัดการบัญชี [5]

2.6 Cache และการติดตามสถานะ

FastCGI cache เก็บผลตอบกลับจากการประมวลผล เพื่อลดงานซ้ำของ PHP-FPM และฐานข้อมูล ต้องยกเว้นคำขอที่มีข้อมูลเฉพาะบุคคลหรือเปลี่ยนแปลงข้อมูล ส่วน Log และการตรวจสถานะช่วยให้เห็นเหตุการณ์และเวลาที่บริการขัดข้อง ข้อมูลจาก cache และระบบติดตามควรนำไปวัดผลจริงก่อนสรุปว่าระบบเร็วหรือพร้อมใช้งานมากขึ้น [6]

บทที่ 3
การออกแบบและดำเนินงาน

3.1 ข้อกำหนดและทรัพยากร

กลุ่มใช้ AWS EC2 t3.micro มี 2 vCPU, RAM 1 GB, swap 1 GB และพื้นที่ดิสก์ 13.4 GB อยู่ในภูมิภาค ap-southeast-2 ซิดนีย์ ตั้ง CPU credit เป็นโหมด Standard เครื่องมี IP สาธารณะ 16.178.135.47 และ IP Tailscale 100.91.199.108

องค์ประกอบ	หน้าที่
Ubuntu	ระบบปฏิบัติการแม่ข่าย
nginx	รับ HTTP/HTTPS และจัดการ cache
PHP-FPM และ WordPress	ประมวลผลและจัดการเนื้อหาเว็บไซต์
MySQL	จัดเก็บข้อมูลเว็บไซต์
DuckDNS และ Let’s Encrypt	ชื่อโดเมนและใบรับรอง TLS
nftables และ Tailscale	ควบคุมการเข้าถึงและช่องทางผู้ดูแล

ระบบใช้ Ubuntu 26.04.1 LTS, nginx 1.28.3, PHP 8.5.4 แพ็กเกจ 8.5.4-0ubuntu1.5, MySQL 8.4.11, WordPress 7.1.3 และ certbot 5.8.0

3.2 การแยกช่องทางสื่อสาร

ช่องทางผู้ใช้ทั่วไปเปิด TCP 80 สำหรับเปลี่ยนเส้นทางไป HTTPS และ TCP 443 สำหรับเว็บไซต์ โดย nftables จำกัดต้นทางเป็น IP ไทย ช่องทางผู้ดูแลใช้ Tailscale และเปิด SSH เฉพาะ interface tailscale0 ส่วน MySQL รับเฉพาะ loopback เพื่อไม่ให้เครื่องภายนอกเชื่อมต่อฐานข้อมูลโดยตรง

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.3 แผนผังและลำดับการเชื่อมต่อ

ภาพที่ 3.1 แผนผังเชิงตรรกะของระบบ

ผู้ใช้ ⟶ DNS ของ DuckDNS ⟶ ได้ IP ของเครื่องแม่ข่าย

ผู้ใช้ ⟶ AWS Security Group ⟶ nftables ⟶ nginx HTTPS

nginx ⟶ PHP-FPM ผ่าน FastCGI ⟶ WordPress ⟶ MySQL

ผู้ดูแล ⟶ Tailscale ⟶ tailscale0 ⟶ OpenSSH หรือ Dashboard

DNS เป็นขั้นตอนค้นหาหมายเลขปลายทางก่อนการเชื่อมต่อเว็บ เส้นทางจริงยังผ่านโครงข่ายอินเทอร์เน็ตและอุปกรณ์เครือข่ายของผู้ให้บริการ แผนผังนี้แสดงองค์ประกอบเชิงตรรกะที่เกี่ยวกับขอบเขตโครงงาน โดยไม่ได้แสดงทุกอุปกรณ์ระหว่างทาง

ต้นทาง	ปลายทางและพอร์ต	แนวทางควบคุม
ผู้ใช้ IP ไทย	เว็บ TCP 80/443	ผ่าน Security Group และรายการ IP ไทย
ผู้ดูแลที่อนุญาต	SSH TCP 22	ผ่าน Tailscale และกุญแจ SSH
ผู้ดูแลที่อนุญาต	Dashboard TCP 443	ผ่าน Tailscale และ Basic Auth
โปรแกรมในเครื่อง	MySQL TCP 3306	รับเฉพาะ 127.0.0.1
ระบบแม่ข่าย	DNS และบริการภายนอก	ต้องมีขาออกที่จำเป็นสำหรับอัปเดตและแจ้งเตือน

nftables เปิด UDP 41641 ให้ Tailscale เชื่อมต่อแบบตรง (direct) ได้ หากเชื่อมตรงไม่ได้ Tailscale จะส่งผ่านตัวกลาง DERP แทน การปิด TCP 22 สาธารณะจึงไม่กระทบการใช้งาน Tailscale [4]

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.4 การติดตั้งและตั้งค่าบริการเว็บ

ติดตั้ง nginx, PHP-FPM, MySQL และ WordPress จากแหล่งที่เชื่อถือได้ สร้างฐานข้อมูลและบัญชีเฉพาะสำหรับเว็บไซต์ กำหนด MySQL ให้ฟังเฉพาะ 127.0.0.1 แล้วตรวจด้วย ss -tlnp จากนั้นกำหนดชื่อโดเมนให้ชี้มายัง IP ของเครื่องและตรวจการตอบกลับก่อนเพิ่มกฎจำกัดการเข้าถึง

กลุ่มออกใบรับรอง Let’s Encrypt ด้วย DNS challenge ของ DuckDNS และกำหนดให้ HTTP เปลี่ยนเส้นทางไป HTTPS ผล certbot renew --dry-run ผ่าน และเว็บไซต์ให้บริการผ่าน HTTPS ได้จริง

เพิ่ม Security Headers ตามความเหมาะสม เช่น HSTS, X-Content-Type-Options และ Referrer-Policy ทั้งนี้ HSTS ควรเปิดเมื่อยืนยันการทำงาน HTTPS และการต่ออายุใบรับรองแล้ว เพราะเบราว์เซอร์จะจดจำข้อกำหนดให้ใช้ HTTPS ตามระยะเวลาที่ตั้งไว้

3.5 การตั้งค่า SSH และ Firewall

กลุ่มสร้างบัญชีผู้ดูแลแทนการเข้า root โดยตรง ใช้กุญแจ ed25519 พร้อม passphrase ปิด root login และการยืนยันตัวตนด้วยรหัสผ่าน ตั้ง TCP 22 ให้รับเฉพาะ tailscale0 และลบกฎ SSH สาธารณะใน AWS Security Group บัญชี Tailscale ล็อกอินด้วย GitHub ที่เปิด 2FA และเครื่องผู้ดูแลตั้ง hosts ให้ชื่อโดเมนชี้ไป IP Tailscale เพื่อเข้า Dashboard

กลุ่มกำหนด nftables แบบปฏิเสธโดยปริยาย อนุญาต loopback และการเชื่อมต่อ established หรือ related แล้วเพิ่มกฎเว็บเฉพาะ IP ไทย รายการประเทศอัปเดตตามรอบและเก็บไฟล์เดิมสำหรับย้อนกลับ กลุ่มทดสอบแล้วว่ากฎยังคงอยู่หลังรีบูต

โครงงานกำหนดรายการประเทศสำหรับ IPv4 ส่วนการตรวจเส้นทาง IPv6 และกฎที่เกี่ยวข้องอยู่ในแผนทดสอบเพิ่มเติมตามหัวข้อ 4.3 [3]

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.6 การลดความเสี่ยงระดับโปรแกรม

กำหนด nginx ไม่ให้เข้าถึงไฟล์ตั้งค่า ไฟล์ซ่อน และไฟล์สำรอง ปิดการรัน PHP ใน uploads และลดการเปิดเผยรายชื่อผู้ใช้ผ่านช่องทางที่ไม่จำเป็น โดยตรวจว่าการแก้ไขเนื้อหาและฟังก์ชัน WordPress ที่ต้องใช้ยังทำงานได้ ไม่ควรถือว่าการเปลี่ยนชื่อบัญชีหรือ prefix ตารางเป็นมาตรการหลักแทนการอัปเดตและการควบคุมสิทธิ์

กลุ่มใช้ 2FA สำหรับผู้ดูแล WordPress และตั้ง nginx จำกัดคำขอ wp-login.php ที่อัตราพื้นฐาน 10 ครั้งต่อนาทีต่อ IP โดยมี burst 5 เมื่อเกินเงื่อนไขการรับคำขอ nginx ตอบ 429 ส่วนสิทธิ์ไฟล์กำหนดตามบัญชี deploy และบัญชีบริการให้เขียนได้เฉพาะส่วนที่จำเป็น [5]

3.7 การตั้งค่า FastCGI cache

กลุ่มตั้งอายุ FastCGI cache 60 นาที ยกเว้นหน้าแอดมิน ผู้ใช้ที่เข้าสู่ระบบ และคำขอ POST โดยพิจารณา cookie, session, query string และคำตอบที่มี Set-Cookie เพื่อไม่เก็บข้อมูลเฉพาะบุคคลลง cache [6]

ใช้ Header X-Cache แสดงสถานะ MISS หรือ HIT สำหรับตรวจการทำงาน พร้อมเก็บเวลาตอบสนองและจำนวนตัวอย่างภายใต้เงื่อนไขเดียวกัน ควรตรวจการล้าง cache เมื่อแก้ไขเนื้อหา เพื่อไม่ให้ผู้ใช้ได้รับข้อมูลเก่าตามอายุ cache โดยไม่ตั้งใจ

3.8 เว็บไซต์แนะนำหลักสูตร

เว็บไซต์วางโครงหน้าแรก หลักสูตร รายวิชา อาจารย์ รับสมัคร และข่าวสารหรือติดต่อ รายละเอียดหลักสูตร หน่วยกิต ค่าใช้จ่าย และข้อมูลรับสมัครต้องอ้างอิงหน่วยงานเจ้าของหลักสูตร และตรวจความครบถ้วนก่อนใช้เป็นผลสำเร็จของโครงงาน

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.9 การเฝ้าระวังและการแจ้งเตือน

Dashboard รวบรวมสถิติจาก nginx, fail2ban และ SSH ทุกชั่วโมง แสดงตัวเลขและกราฟตามช่วงเวลา พร้อมใช้ Gemini สรุปแนวโน้มความเสี่ยงเป็นภาษาไทยในหน้าเดียว

กลุ่มเก็บข้อมูลรับรอง API และ Telegram ในไฟล์ที่จำกัดสิทธิ์ และส่งให้ AI เฉพาะสถิติที่คำนวณแล้วกับ IP ที่ปิดเลขท้าย คำตอบของ AI ผ่านการ escape ก่อนแสดงบน Dashboard

กลุ่มผูกสคริปต์แจ้ง Telegram กับ PAM เมื่อมี SSH login และใช้ watchdog ตรวจบริการกับหน้าเว็บทุกนาที การแจ้งเตือนเว็บเน้นสถานะ DOWN และ UP เพื่อลดข้อความซ้ำ และบันทึกเหตุการณ์ไว้ใน Log

nginx Log หมุนไฟล์ทุกวันและเก็บย้อนหลัง 14 วัน ส่วน Dashboard บันทึกยอดสรุปรายวันแยกไว้ใน history.json ทำให้ดูสถิติย้อนหลังต่อได้แม้ Log ต้นทางพ้นรอบเก็บรักษาแล้ว

3.10 การสำรองและการกู้คืน

สำรองฐานข้อมูลและไฟล์เว็บทุกวัน เก็บย้อนหลัง 7 วัน และจัดสำเนานอกเครื่องตามแผนที่กำหนด การสำรองอยู่บนเครื่องเดียวไม่เพียงพอเมื่อเครื่องเสียหรือถูกยึดสิทธิ์ จึงต้องมีการนำออกนอกเครื่องและทดสอบกู้คืน การอัปเดตอัตโนมัติควรมี Log และแผนรับมือกรณีบริการต้องรีสตาร์ท

การใช้ systemd ให้บริการกลับมาหลังโปรเซสล้ม และการใช้ watchdog ตรวจระดับ HTTP มีหน้าที่ต่างกัน ควรจำกัดการรีสตาร์ทซ้ำและเก็บสาเหตุไว้ เพราะการรีสตาร์ทอย่างเดียวอาจกลบปัญหาฐานข้อมูล ดิสก์เต็ม หรือการตั้งค่าที่ผิด

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.11 กับดักตรวจจับการสแกนเส้นทางเว็บ

ระบบเพิ่มเส้นทางล่อซึ่งไม่มีบริการจริง ได้แก่ /phpmyadmin, /pma, /wp-admin-backup, /old-admin, /backup.zip และ /db.sql โดย nginx ตอบ 404 และบันทึกลง honeypot.log จากนั้น fail2ban อ่านเหตุการณ์แล้วเพิ่มกฎแบน IP ที่พอร์ตเว็บ แนวทางนี้เป็นกับดักระดับเส้นทาง HTTP ไม่ใช่การเปิดบริการฐานข้อมูลจำลองให้ผู้โจมตีใช้งาน

รายการ	**ค่าที่ตั้งค่าและทดสอบ ณ 30 ตุลาคม 2569**
เกณฑ์ Honeypot	maxretry = 1 แบน 24 ชั่วโมง
ขอบเขตแบน	IP ต้นทางที่พอร์ต 80 และ 443
รายการยกเว้น	localhost และช่วง Tailscale 100.64.0.0/10
Log	/var/log/nginx/honeypot.log
ไฟล์ filter และ jail	/etc/fail2ban/filter.d/honeypot.conf /etc/fail2ban/jail.d/honeypot.conf
jail อื่น	sshd และ nginx-forbidden (403 ครบ 5 ครั้งใน 10 นาที แบน 1 ชั่วโมง)

เมื่อมีคำขอเข้าเส้นทางล่อ nginx ตอบ 404 และบันทึกเหตุการณ์ให้ fail2ban เพิ่มกฎแบน IP ส่วน /.env ตอบ 403 และอยู่ในขอบเขต jail nginx-forbidden การปฏิเสธคำขอครั้งเดียวกับการแบน IP จึงเป็นคนละกลไก

ลิงก์อาจถูกเปิดโดยผู้ใช้ที่ได้รับการส่งต่อ หรือโปรแกรมสร้างภาพตัวอย่างลิงก์ จึงมีโอกาสแบนผิด ยิ่งต้นทางใช้ NAT ร่วมกัน ผู้ใช้หลายคนอาจได้รับผลกระทบ ต้องมีวิธีปลดแบนและบันทึกการยกเว้น โดยไม่ถือว่าผู้เปิดทุกคนเป็นผู้โจมตี

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.12 การตรวจไฟล์และจำกัด PHP

กลุ่มตั้ง integrity-check.sh ตรวจ WordPress core และปลั๊กอินด้วย WP-CLI ทุกวันเวลา 10:17 น. (เวลาไทย) และแจ้ง Telegram เมื่อ checksum ไม่ตรง ขอบเขตตรวจไม่รวมธีม mu-plugins ฐานข้อมูล และไฟล์สื่อ [9]

กลุ่มทดสอบแก้ version.php หนึ่งบรรทัดแล้วเรียกตรวจ ระบบพบความเปลี่ยนแปลงและแจ้ง Telegram เมื่อคืนไฟล์แล้วตรวจปลั๊กอิน ระบบแสดง Verified 3 of 3 plugins

กลุ่มตั้ง disable_functions ของ PHP-FPM สำหรับ exec, passthru, shell_exec, system, proc_open, popen และ pcntl_exec ผลทดสอบ exec ไม่ทำงาน ขณะที่หน้าแรกยังตอบ 200 [8]

3.13 การดูแลกฎและข้อมูลรับรอง

กลุ่มพบว่าการใช้ flush ruleset ล้างกฎที่ fail2ban และ Tailscale สร้างขึ้นด้วย จึงตรวจสถานะทั้งสองบริการหลังโหลด ruleset และกำหนดแผนย้อนกลับผ่านช่องทางกู้คืน การแยกตารางที่ดูแลเป็นแนวทางปรับปรุงระยะถัดไป

กลุ่มเพิกถอน API key ที่เคยปรากฏในภาพหน้าจอและออก key ใหม่ แล้วเก็บในไฟล์ที่จำกัดสิทธิ์แทนการใส่ค่าไว้ในโค้ดหรือรายงาน

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.14 การปรับระบบหลังตรวจความปลอดภัย

กลุ่มแก้ F1–F4 และตรวจซ้ำด้วยไฟล์ชุดใหม่เมื่อ 30 ตุลาคม 2569 ครอบคลุมการตรวจข้อมูลก่อนสร้างกฎ Firewall การควบคุมสิทธิ์ใน WordPress ลำดับ location ของ nginx และข้อยกเว้น IP ใน fail2ban

การรับรายการ IP และการโหลดกฎ

กลุ่มปรับสคริปต์อัปเดตประเทศให้คัดกรองรูปแบบ IPv4/CIDR ตรวจจำนวนบรรทัดที่ผ่านเทียบกับข้อมูลทั้งหมด และตรวจ ruleset ด้วย nft -c ก่อนใช้ หากไม่ผ่านจะคืนไฟล์เดิม ผลอัปเดตหลังแก้ได้ 667 ช่วง IP จากเดิม 665 ช่วง ส่วนการจำกัด prefix ที่กว้างผิดปกติเป็นประเด็น R2

ยืนยันตัวตนใน WordPress

เพิ่ม mu-plugin hide-users.php ให้ WordPress ตรวจ is_user_logged_in() ก่อนเปิดเส้นทาง REST รายชื่อผู้ใช้ การเห็นชื่อ cookie ใน nginx ไม่ใช่การยืนยันว่าเข้าสู่ระบบจริง จึงใช้ nginx เป็นชั้นเสริม และให้โปรแกรมตรวจ session เอง ทั้งนี้ sitemap oEmbed และชื่อที่แสดงยังต้องตรวจใน N1

ลำดับกฎและข้อยกเว้นการแบน

กลุ่มย้าย location ของ Honeypot ก่อนกฎนามสกุลไฟล์ ทำให้ /db.sql ตอบ 404 และเข้า honeypot.log และแก้ ignoreip ของ fail2ban ให้ครอบคลุม jail ฝั่งเว็บ หลังพบว่าค่าเดิมมีผลเฉพาะ sshd

แนวทางพัฒนารอบถัดไปเน้นขอบเขต regex ของเส้นทางล่อ การปฏิเสธเครือข่ายที่กว้างผิดปกติ และการลดการรีสตาร์ท Tailscale รายละเอียดอยู่ในหัวข้อ 4.11

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.15 ขั้นตอน HTTPS ด้วย DNS challenge

DNS-01 พิสูจน์ว่าผู้ขอใบรับรองควบคุมระเบียน DNS ของชื่อโดเมนได้ โดยไม่ต้องให้ Let’s Encrypt เข้ามาอ่านไฟล์ผ่าน HTTP ที่ VPS จึงเหมาะกับเว็บไซต์ที่จำกัด IP ต่างประเทศ แต่ระเบียน DNS ที่ใช้ตรวจต้องเผยแพร่ให้ระบบตรวจสอบภายนอกมองเห็น [1]

1. Certbot ติดต่อบริการ ACME ของ Let’s Encrypt เพื่อขอใบรับรองสำหรับ betterson.duckdns.org และรับข้อมูล challenge

2. Certbot คำนวณค่า challenge สำหรับ DNS และใช้ปลั๊กอิน DuckDNS พร้อม token ที่ได้รับสิทธิ์ เพื่อเพิ่มระเบียน TXT ที่ใช้ยืนยันโดเมน

3. จุดตรวจ DNS-01 ใช้ชื่อ _acme-challenge.betterson.duckdns.org และรอให้ค่าที่กำหนดเผยแพร่ใน DNS ก่อนให้ผู้ให้บริการใบรับรองตรวจ

4. Let’s Encrypt สอบถาม DNS สาธารณะเพื่อตรวจค่า TXT ไม่ได้ขอไฟล์จาก TCP 80 ของเครื่อง VPS จึงไม่ต้องเปิดยกเว้น geo-block สำหรับ HTTP challenge

5. เมื่อพิสูจน์สิทธิ์ผ่าน จะได้รับใบรับรองและนำไปตั้งค่า nginx ให้บริการ HTTPS พร้อมทดสอบชื่อโดเมนและสายโซ่ใบรับรอง

6. เมื่อตรวจเสร็จ ปลั๊กอินจัดการระเบียน challenge ตามกระบวนการที่ตั้งไว้ และการต่ออายุต้องทำขั้นตอน DNS ได้โดยอัตโนมัติเช่นเดิม

กลุ่มเก็บ token ของ DuckDNS ใน /etc/letsencrypt/duckdns.ini เจ้าของ root และสิทธิ์ 600 เพื่อให้ Certbot ใช้จัดการ TXT record โดยไม่เปิดเผยข้อมูลรับรองในหน้าเว็บ

บทที่ 3 การออกแบบและดำเนินงาน ต่อ

3.16 การแพตช์ช่องโหว่ PHP

เมื่อมีประกาศ CVE-2026-109618 และ CVE-2026-109619 ซึ่งอาจทำให้ผู้โจมตีรันโค้ดจากระยะไกลใน PHP ที่ให้บริการเว็บ กลุ่มตรวจรุ่นแพ็กเกจที่ใช้งานและอัปเดตด้วย apt โดย PHP upstream แก้ปัญหาในรุ่น 8.5.12 [11]

เครื่องของกลุ่มใช้แพ็กเกจ Ubuntu รุ่น 8.5.4-0ubuntu1.5 ซึ่งนำแพตช์กลับมาใส่ในรุ่นที่แจกจ่ายเดิม หรือ backport โดยไม่เปลี่ยนเลขหลักให้เป็น 8.5.12 ประกาศ Ubuntu USN-8948-1 ระบุรุ่นนี้เป็นรุ่นแก้ไขสำหรับ PHP 8.5 บน Ubuntu 26.04 LTS [12]

กลุ่มตรวจ changelog ของแพ็กเกจ พบชื่อแพตช์ของ CVE ทั้งสองตัว แล้วรีสตาร์ท php8.5-fpm เพื่อให้ worker ใช้ไลบรารีและโค้ดที่อัปเดตแล้ว จากนั้นตรวจสถานะบริการและการเปิดเว็บไซต์

กรณีนี้แสดงว่าการดู php -v เพียงอย่างเดียวไม่เพียงพอต่อการประเมินสถานะแพตช์ ต้องพิจารณารุ่นแพ็กเกจของผู้แจกจ่ายร่วมกับประกาศความปลอดภัยและ changelog กลุ่มจึงบันทึกทั้งเลขรุ่น PHP และเลขแพ็กเกจ Ubuntu ไว้ในข้อมูลระบบ

ลำดับการดำเนินงาน

1. ตรวจประกาศช่องโหว่และรุ่นแพ็กเกจที่ได้รับผลกระทบ
2. อัปเดตแพ็กเกจด้วย apt และตรวจ changelog
3. รีสตาร์ท PHP-FPM แล้วตรวจบริการกับหน้าเว็บไซต์

บทที่ 4
ผลการดำเนินงานและการทดสอบ

4.1 แนวทางประเมินผล

กลุ่มประเมินระบบด้วยการทดสอบการเชื่อมต่อ SSH และเว็บไซต์ การปฏิเสธคำขอ การจำกัดความถี่ การทำงานของ cache การแจ้งเตือน และการกู้คืนบริการ โดยสรุปผลเทียบกับพฤติกรรมที่ออกแบบไว้

กรณีทดสอบ	ผลทดสอบ	การแปลผล
SSH ผ่าน IP สาธารณะ	Connection timed out	ยืนยันการเข้าถึงไม่ได้จากต้นทางที่ทดสอบ
SSH ผ่าน Tailscale	เข้าใช้งานได้	ผู้ดูแลบริหารเครื่องผ่านเครือข่ายส่วนตัว
HTTPS และต่ออายุจำลอง	ใช้งานได้และ dry-run ผ่าน	เว็บใช้งานผ่าน HTTPS ได้จริง
เข้าจากเครือข่ายไทย	เข้าใช้งานได้	ผู้ใช้จาก IP ไทยเชื่อมต่อเว็บไซต์ได้
เข้าจาก VPN ต่างประเทศ	Connection timed out	เครือข่าย VPN ต่างประเทศเข้าเว็บไม่ได้

ผล SSH ผ่าน IP สาธารณะหมดเวลารอ ขณะที่ผู้ดูแลใช้ช่องทาง Tailscale พร้อมกุญแจ SSH สำหรับบริหารเครื่องตามการออกแบบ

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.2 ผลด้านการป้องกันและการกู้คืน

รายการ	ผลทดสอบ	**การแปลผล**
ไฟล์ .env และ wp-config.php	ตอบกลับ 403 หลังเพิ่มกฎ	nginx ปฏิเสธคำขอที่ทดสอบ
PHP ใน uploads	จาก 200 เป็น 403	nginx ปฏิเสธการรัน PHP ในโฟลเดอร์ uploads
การแสดงรายชื่อผู้ใช้	ช่องทางที่ทดสอบตอบ 403	/wp-json/wp/v2/users และ /?author=1 ตอบ 403
FastCGI cache	MISS แล้ว HIT	ยืนยันการใช้ cache ในกรณีที่ทดสอบ
จำกัดการเข้าสู่ระบบ	พบ HTTP 429	nginx จำกัดอัตราพื้นฐาน 10 ครั้งต่อนาที มี burst 5 และตอบ 429 เมื่อเกินเงื่อนไข
ฆ่าโปรเซส nginx	กลับมา active ภายใน 8 วินาที	เป็นการทดสอบโปรเซสล้ม
หยุดบริการ nginx	19:51:02 ถึง 19:52:02	ช่วงเวลาที่บันทึกไว้ประมาณ 60 วินาที

HTTP 200 จาก wp-config.php ก่อนเพิ่มกฎไม่ได้แปลว่าไฟล์รหัสลับถูกเปิดเผยเสมอไป เพราะ PHP อาจประมวลผลแล้วตอบกลับโดยไม่มีเนื้อหา ต้องตรวจเนื้อหาคำตอบและเส้นทางประมวลผลด้วย การเปลี่ยนเป็น 403 จึงแสดงการปฏิเสธคำขอตรงในกรณีทดสอบ แต่ไม่ใช่หลักฐานว่าระบบเคยรั่วข้อมูล

ช่วงเวลา 8 วินาทีกับ 60 วินาทีเป็นคนละวิธีทดสอบ ไม่ควรรวมเป็นค่าเฉลี่ยหรือถือเป็น SLA ของระบบ หากต้องการประเมินความพร้อมใช้งานควรทดสอบซ้ำและเก็บเวลาจากจุดตรวจภายนอก

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.3 ประเด็นที่ต้องทดสอบเพิ่มเติม

กลุ่มทดสอบผ่าน VPN ต่างประเทศแล้วพบ ERR_CONNECTION_TIMED_OUT ส่วนการทดสอบ IPv6 พอร์ตฐานข้อมูลจากภายนอก และสิทธิ์ Dashboard หลายเงื่อนไขเป็นแนวทางประเมินเพิ่มเติม

ด้านประสิทธิภาพ มีผล ApacheBench ภายในเครื่องตามหัวข้อ 4.5 แล้ว ควรทดสอบซ้ำหลายรอบจากเครื่องภายนอก เก็บค่ามัธยฐานและ percentile พร้อม CPU/RAM และตรวจเนื้อหาคำตอบให้ตรงกัน ผลปัจจุบันเป็นค่าจากรอบที่บันทึกไว้ ไม่ใช่เวลาที่ผู้ใช้อินเทอร์เน็ตทุกคนจะได้รับ

ด้านการกู้คืน ควรทดสอบสำรองและกู้คืนบนสภาพแวดล้อมแยก ตรวจความครบถ้วนของบทความ สื่อ และฐานข้อมูล พร้อมบันทึกเวลาที่ใช้ การมีไฟล์สำรองโดยไม่เคยทดสอบกู้คืนยังไม่ยืนยันว่าระบบกู้กลับมาได้

4.4 อภิปรายผล

การย้ายช่องทาง SSH ไป Tailscale ช่วยลดการเปิดเผย TCP 22 ต่ออินเทอร์เน็ต และลดปัญหาที่ผู้ดูแลมี IP เปลี่ยนแปลง อย่างไรก็ตาม ความปลอดภัยยังขึ้นอยู่กับสิทธิ์ใน tailnet อุปกรณ์ผู้ดูแล และการรักษากุญแจส่วนตัวด้วย

การจำกัดประเทศลดกลุ่มต้นทางที่เข้าเว็บได้ แต่ผู้โจมตีอาจใช้เครือข่ายไทยหรือ VPN ไทย ขณะที่ผู้ใช้ที่ได้รับอนุญาตซึ่งอยู่ต่างประเทศอาจเข้าเว็บไม่ได้ จึงเป็นมาตรการจำกัดพื้นที่ตามข้อกำหนดและต้องใช้ร่วมกับการยืนยันตัวตน การอัปเดต และการติดตามเหตุการณ์

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.5 ผลทดสอบประสิทธิภาพ FastCGI cache

วันที่ 30 ตุลาคม 2569 กลุ่มใช้ ApacheBench ส่งคำขอหน้าแรก 200 ครั้ง พร้อมกัน 10 คำขอ จากเซิร์ฟเวอร์ไปยัง HTTPS ที่ 127.0.0.1 โดยกำหนด Host เป็นโดเมนเว็บไซต์ รอบเปรียบเทียบใช้ cookie ให้ nginx ข้าม cache แบบ BYPASS [7]

ตัวชี้วัด	HIT	BYPASS
Requests per second	548.30	19.96
Time per request mean	18.238 ms	500.939 ms
Mean across concurrent requests	1.824 ms	50.094 ms
Failed requests	0	0

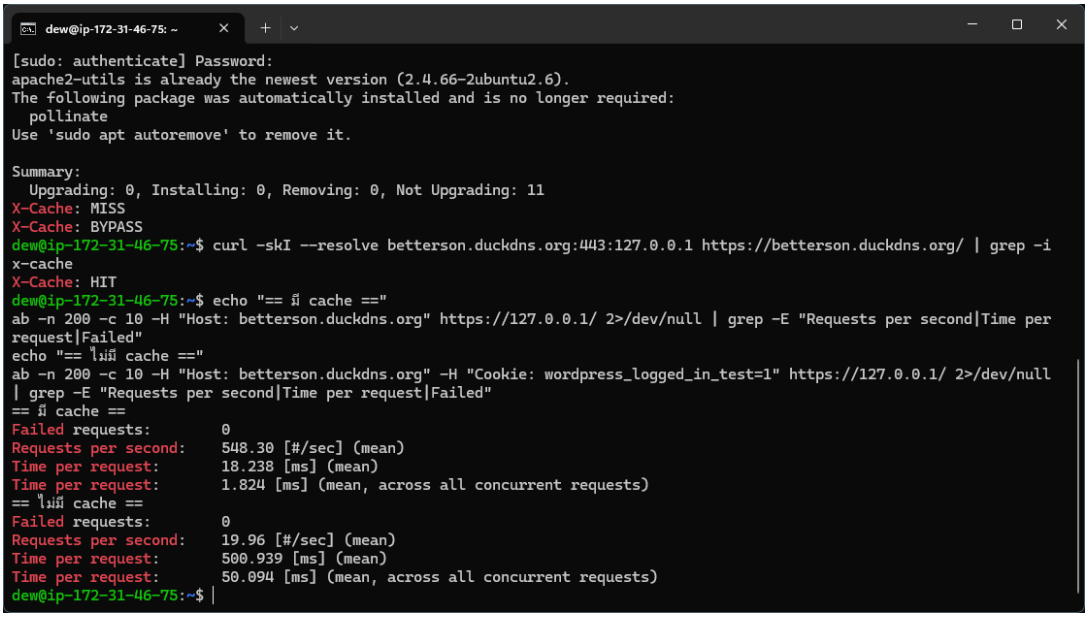
อัตราส่วน throughput เท่ากับ 548.30 ÷ 19.96 = 27.47 เท่า ส่วนค่า Time per request mean ลดลงประมาณ 96.36% ทั้งสองรอบใช้ concurrency 10 เท่ากัน ค่า mean กับ mean across concurrent requests เป็นคนละบรรทัดในผล ApacheBench จึงไม่ควรนำมาสลับกันหรือเรียกทั้งหมดว่าเวลาจริงของผู้ใช้ [7]

ข้อจำกัดคือเครื่องทดสอบเป็นเครื่องเดียวกับเว็บ จึงไม่รวมเครือข่ายอินเทอร์เน็ต และตัวสร้างภาระงานแย่งทรัพยากรกับเว็บ ภาพแสดงผลรอบเดียวและตัดบางส่วนของผลออก ยังต้องตรวจ status และเนื้อหาคำตอบให้ตรงกันทุกคำขอ รวมทั้งควบคุม CPU credit และทดสอบซ้ำก่อนอ้างเป็นขีดความสามารถทั่วไป

ผลสนับสนุนว่า cache ช่วยลดงานประมวลผลในกรณีที่ทดสอบ แต่ไม่ใช่หลักฐานว่าทน DDoS เพิ่ม 27 เท่า เพราะการโจมตีอาจใช้เส้นทางที่ BYPASS cache หรือทำให้เครือข่ายเต็มก่อนถึง nginx

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.6 หลักฐานหน้าจอ ApacheBench



ภาพที่ 4.1 ผล ApacheBench ของกรณี cache และ BYPASS

ที่มา ผลทดสอบ ApacheBench ของกลุ่ม วันที่ 30 ตุลาคม 2569

ภาพแสดงคำสั่ง ab -n 200 -c 10 และผล HIT กับ BYPASS ตามตาราง กลุ่มตรวจ X-Cache ด้วย curl ที่กำหนดชื่อโดเมนไปยัง 127.0.0.1

คำสั่ง curl ในภาพใช้ -k เพื่อทดสอบ Header ภายในเครื่อง ส่วนการตรวจใบรับรองและการต่ออายุใช้การทดสอบ HTTPS แยกจากการวัด cache

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.7 สถิติจาก Log และขอบเขตการตีความ

กลุ่มวิเคราะห์ nginx Log ตั้งแต่ 21 ตุลาคม 2569 เวลา 17:22 ถึง 29 ตุลาคม 2569 เวลา 12:15 UTC หรือ 22 ตุลาคม เวลา 00:22 ถึง 29 ตุลาคม เวลา 19:15 ตามเวลาไทย พบ 5,123 คำขอจาก 109 IP ไม่ซ้ำ

HTTP status	จำนวน	ความหมายโดยสรุป
200	4,413	คำตอบสำเร็จ
302 / 304 / 301	284 / 208 / 57	เปลี่ยนเส้นทาง / ใช้ cache ฝั่งผู้ใช้
404	97	ไม่พบทรัพยากร
500	17	ข้อผิดพลาดฝั่งเซิร์ฟเวอร์
403	14	ปฏิเสธคำขอ
401	7	ต้องยืนยันตัวตนหรือข้อมูลรับรองไม่ผ่าน
429	3	จำกัดความถี่คำขอ

ตารางแสดงเฉพาะ status หลัก

กลุ่มพบคำขอไป /.env 4 ครั้ง /.git/config 3 ครั้ง และ /wp-config.php 2 ครั้ง ได้ 403 หรือ 404 ส่วน /secdash/ ถูกปฏิเสธ 8 ครั้ง ซึ่งรวมการทดสอบของกลุ่มด้วย

Dashboard แต่ละชุดแสดงผลตามช่วงเวลาที่เลือก คำขอ WordPress Heartbeat และไฟล์ประกอบหน้าเป็นการใช้งานปกติ ส่วนทราฟฟิกที่ถูกทิ้งก่อนถึง nginx ไม่ปรากฏใน access log

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.8 ผลกับดักและสถานะงานที่เหลือ

วันที่ 30 ตุลาคม 2569 เวลา 01:12 กลุ่มทดสอบให้เพื่อนสองคนเปิด /old-admin ผ่านลิงก์ที่ส่งทาง Instagram แล้วพบ Currently banned: 2 และ Total banned: 2 จากนั้นปลดแบนหลังทดสอบ อีกช่วงทดสอบแสดง Currently banned: 1 และ Total banned: 4 จึงแสดงภาพแยกตามรอบในภาคผนวก จ

การส่งลิงก์ให้คนปกติแล้วถูกแบนแสดงด้วยว่ากฎไม่ได้จำแนกเจตนาหรือแยกคนออกจากบอท User-Agent และ Referer เป็นค่าที่อาจขาดหายหรือปลอมได้ ไม่ใช้ยืนยันรุ่นอุปกรณ์ แอป หรือบุคคลอย่างเด็ดขาด และเกณฑ์แบนที่ครั้งแรกอาจกระทบ IP สาธารณะที่หลายคนใช้ร่วมกัน

งาน	สถานะตามข้อมูลล่าสุด
VPN ต่างประเทศ / IPv6	VPN ต่างประเทศผ่าน / IPv6 อยู่ในแผนทดสอบ
สร้าง backup codes ของ 2FA	ยังเกิด HTTP 500 ส่วน TOTP ใช้งานได้
Content-Security-Policy	ยังไม่ได้ตั้งค่า
WP_DEBUG	ปิดและลบ debug.log แล้ว
การตรวจไฟล์ด้วย WP-CLI	ตรวจพบไฟล์ที่เปลี่ยนและแจ้ง Telegram
ทดสอบกู้คืนสำรอง	ยังไม่ได้ทดสอบกู้คืน

กลุ่มปิด WP_DEBUG และลบ debug.log หลังใช้งานวิเคราะห์ปัญหา ส่วนการสร้าง backup codes ของ 2FA ยังเกิด HTTP 500 โดย TOTP ใช้งานได้ตามปกติ ประเด็นนี้คงเป็นข้อจำกัดของระบบ

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.9 ขอบเขตและวิธีตรวจความปลอดภัย

กลุ่มตรวจด้วย security-audit skill ของ Cloudflare แบบ quick profile โดยมีผู้ตรวจอิสระทบทวนข้อค้นพบ รอบแรกครอบคลุม 23 ไฟล์ 803 บรรทัด และรอบสองใช้ 26 ไฟล์ รวม jail ที่เพิ่มเข้ามาและ mu-plugin การพิสูจน์ F1 ระหว่างตรวจรอบแรกใช้สภาพแวดล้อมทดลองแยก [13]

ตัวชี้วัดตามเอกสาร	รอบแรก	รอบสอง
ไฟล์ที่ตรวจ	23	26
ระดับ Critical หรือ High	ไม่พบในขอบเขตตรวจ	ไม่พบในขอบเขตตรวจ
ระดับกลาง	1 ข้อ F1	0 ข้อ
ระดับต่ำ	2 ข้อ F2 F3	3 ข้อ R1 R2 R3
ต้องตรวจบนเครื่อง	F4 ต่อมายืนยันว่ามีปัญหา	N1 ยังต้องตรวจ

รอบแรกขาดไฟล์ jail ฝั่งเว็บและ nginx.conf หลัก จึงมีข้อจำกัดในการสรุปพฤติกรรมจากซอร์ส ส่วนการตรวจไม่ได้ประเมิน WordPress core ปลั๊กอินและธีมทั้งหมด หรือทดสอบเจาะระบบเต็มรูปแบบ การไม่พบ Critical หรือ High จึงใช้สรุปได้เฉพาะขอบเขตและรอบตรวจนี้

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.10 ข้อค้นพบที่แก้และตรวจซ้ำแล้ว

รหัส	ข้อค้นพบเดิม	ผลหลังแก้และตรวจซ้ำ
F1 กลาง	รายการ IP ภายนอกถูกนำมาสร้างกฎโดยตรวจเพียงจำนวนบรรทัด อาจแทรกกฎ nftables ได้	เพิ่มการคัดกรองข้อมูลและ nft -c ก่อนใช้ผลอัปเดตระบุ 667 ช่วง
F2 ต่ำ	กฎ nginx ซ่อนชื่อผู้ใช้ถูกเลี่ยงด้วย cookie หรือรูปแบบ URL	เพิ่ม mu-plugin ตรวจการเข้าสู่ระบบจริง ตัวอย่าง cookie ปลอมได้ rest_no_route
F3 ต่ำ	/db.sql ถูกกฎ .sql จับก่อน จึงไม่เข้า honeypot.log	ย้ายลำดับ location ผลได้ 404 และมีบรรทัดใน Log กับดัก
F4	ignoreip เดิมอยู่ใต้ sshd ทำให้ jail เว็บไม่ได้ยกเว้น	เพิ่มค่า DEFAULT และตรวจรายการยกเว้น ผล Honeypot แสดง loopback กับ Tailscale

กลุ่มแก้ F1–F4 ครบเมื่อ 30 ตุลาคม 2569 เวลา 10:29 และผู้ตรวจรอบสองยืนยันผลในไฟล์ชุดใหม่ กฎ nginx ยังเป็นชั้นเสริมสำหรับ F2 ส่วนการยืนยันการเข้าสู่ระบบของเส้นทาง REST users ทำใน WordPress

ผลตรวจ F1 ทำให้กลุ่มแยกข้อมูลภายนอกออกจากกฎ Firewall และเพิ่มขั้นตอนตรวจข้อมูล ส่วน F3 กับ F4 แก้ด้วยลำดับ location และค่าที่มีผลในแต่ละ jail

บทที่ 4 ผลการดำเนินงานและการทดสอบ ต่อ

4.11 ประเด็นคงเหลือหลังตรวจรอบสอง

รหัส	ประเด็น	สถานะที่ใช้ในรายงาน
N1	ชื่อผู้ใช้อาจเผยผ่าน author sitemap oEmbed บทความ หรือ feed	อยู่ในแผนตรวจบนเครื่องจริง
R1 ต่ำ	regex กับดักจับชื่อขึ้นต้น เช่น /pma-news/ ทำให้ผู้ใช้ปกติติดแบน	อยู่ในแผนเพิ่มขอบเขต regex ด้วย (/|$)
R2 ต่ำ	รายการประเทศยังอาจรับ 0.0.0.0/0 ทำให้เงื่อนไขประเทศถูกเปิดกว้าง	อยู่ในแผนปฏิเสธ prefix /0 ถึง /7
R3 ต่ำ	การ reload กฎล้างทั้ง ruleset แล้วรีสตาร์ท Tailscale อาจล็อกผู้ดูแลออก	รับความเสี่ยงชั่วคราวและวางแผนแยกตาราง Firewall

กลุ่มกำหนด N1 และ R1–R2 เป็นงานพัฒนาต่อ ได้แก่ ตรวจช่องทางแสดงชื่อผู้ใช้ เพิ่มขอบเขต regex ของกับดัก และปฏิเสธ prefix ที่กว้างผิดปกติ ส่วน R3 รับความเสี่ยงชั่วคราวโดยวางแผนเปลี่ยนจาก flush ruleset เป็นการจัดการเฉพาะตาราง

การกู้คืน R3 ต้องมีช่องทางที่ใช้งานได้จริง การเพิ่ม TCP 22 ใน Security Group อย่างเดียวไม่พอหาก nftables ยังทิ้งแพ็กเก็ต ส่วน EC2 Serial Console ต้องตรวจเงื่อนไขและสิทธิ์ก่อนพึ่งพา จึงควรวางแผนย้อนกลับและทดสอบกู้คืนในช่วงที่เหมาะสม

บทที่ 5
สรุปผลและข้อเสนอแนะ

5.1 สรุปผลตามวัตถุประสงค์

โครงงานแสดงการประยุกต์องค์ความรู้ด้านเครือข่ายผ่านการติดตั้งเว็บไซต์บน VPS การใช้ DNS ระบุปลายทาง การสื่อสารผ่าน HTTPS และการแยกบริการตามพอร์ต โดยใช้ Firewall ระดับ AWS และระดับระบบปฏิบัติการร่วมกัน พร้อมแยกช่องทางดูแลเครื่องออกผ่านเครือข่ายส่วนตัว

กลุ่มทดสอบแล้วว่า SSH ผ่าน Tailscale ใช้งานได้ เว็บปฏิเสธเส้นทางสำคัญและจำกัดคำขอเข้าสู่ระบบได้ FastCGI cache เพิ่ม throughput ประมาณ 27.47 เท่าภายใต้การทดสอบภายในเครื่อง ระบบแจ้งการแบนและกู้คืนบริการผ่าน Telegram ผลทดสอบ VPN ต่างประเทศเข้าเว็บไม่ได้ และผลตรวจซอร์สรอบสองยืนยันการแก้ F1–F4 ส่วนรายการพัฒนาต่ออยู่ในหัวข้อ 4.11

5.2 ปัญหาและข้อจำกัด

เครื่องแม่ข่ายขนาดเล็กมีข้อจำกัดด้าน RAM และกำลังประมวลผล swap อาจช่วยลดโอกาสหน่วยความจำหมดแต่ไม่ทดแทน RAM จริง การโจมตีปริมาณมากอาจทำให้ทรัพยากรเต็มได้ แม้ตั้งค่าป้องกันระดับโปรแกรมแล้วก็ตาม

การจัดการรายการประเทศอาศัยข้อมูลจากภายนอก ซึ่งอาจคลาดเคลื่อนหรือล้าสมัย ส่วนระบบแจ้งเตือนและ AI พึ่งพาบริการภายนอก หากเชื่อมต่อไม่ได้ต้องยังมี Log และสถิติพื้นฐานในเครื่อง การสำรองนอกเครื่องแบบนำออกเป็นระยะยังมีช่วงเวลาที่ข้อมูลล่าสุดอาจสูญหาย

งานที่ยังไม่แล้วเสร็จคือการทดสอบกู้คืนข้อมูลสำรอง การสร้าง backup codes ของ 2FA ซึ่งยังเกิด HTTP 500 และการตั้ง Content-Security-Policy ส่วน TOTP และการสำรองข้อมูลตามรอบใช้งานได้

บทที่ 5 สรุปผลและข้อเสนอแนะ ต่อ

5.3 ข้อเสนอแนะในการพัฒนาต่อ

กลุ่มวางแผนตรวจ N1 ปรับ R1–R2 และทดสอบทางกู้คืนกรณี Tailscale ไม่กลับมา จากนั้นทดสอบ IPv6 และการกู้คืนสำรอง แก้ปัญหา backup codes ของ 2FA ทดสอบประสิทธิภาพซ้ำจากภายนอก และพิจารณา CSP แบบ Report-Only

ลำดับต่อมาควรตั้งสำรองนอกเครื่องโดยอัตโนมัติและทดสอบกู้คืนเป็นรอบ กำหนดระยะเวลายอมให้ข้อมูลสูญหายและระยะเวลากู้คืนที่เหมาะสมกับเว็บไซต์ รวมทั้งตรวจพื้นที่จัดเก็บและการหมุนเวียน Log อย่างสม่ำเสมอ

หากเปิดให้บริการวงกว้าง ควรพิจารณาบริการช่วยรับทราฟฟิกและป้องกันการโจมตีที่เหมาะกับโดเมนและงบประมาณ โดยตรวจเงื่อนไขของผู้ให้บริการ การซ่อนต้นทาง และผลต่อการจำกัดประเทศก่อนปรับสถาปัตยกรรม

5.4 สิ่งที่ได้รับจากโครงงาน

ประเด็นสำคัญคือความปลอดภัยเกิดจากความสัมพันธ์ของหลายส่วน ตั้งแต่การระบุปลายทาง การเข้ารหัส การอนุญาตเส้นทางเครือข่าย การยืนยันตัวตน ไปจนถึงการตรวจจับและกู้คืน การอธิบายว่ากฎทำงานอย่างไรต้องมีผลทดสอบประกอบ ไม่ใช้เพียงรายการโปรแกรมที่ติดตั้งหรือคำว่า “ปลอดภัย” เป็นข้อสรุป

โครงงานทำให้กลุ่มเชื่อมโยงการออกแบบเครือข่าย การควบคุมสิทธิ์ และการติดตามเหตุการณ์เข้าด้วยกัน พร้อมใช้ผลทดสอบและการตรวจซอร์สเป็นข้อมูลสำหรับปรับปรุงระบบ

บรรณานุกรม

[1] Let’s Encrypt. (ม.ป.ป.). Challenge Types. สืบค้นเมื่อ 29 ตุลาคม 2569 จาก https://letsencrypt.org/docs/challenge-types/

[2] Amazon Web Services. (ม.ป.ป.). Amazon EC2 security groups for your EC2 instances. สืบค้นเมื่อ 29 ตุลาคม 2569 จาก https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/ec2-security-groups.html

[3] The Netfilter Project. (ม.ป.ป.). nftables manual page. สืบค้นเมื่อ 29 ตุลาคม 2569 จาก https://netfilter.org/projects/nftables/manpage.html

[4] Tailscale. (ม.ป.ป.). What firewall ports should I open to use Tailscale. สืบค้นเมื่อ 29 ตุลาคม 2569 จาก https://tailscale.com/docs/reference/faq/firewall-ports

[5] WordPress.org. (ม.ป.ป.). Hardening WordPress. สืบค้นเมื่อ 29 ตุลาคม 2569 จาก https://developer.wordpress.org/advanced-administration/security/hardening/

[6] nginx. (ม.ป.ป.). Module ngx_http_fastcgi_module. สืบค้นเมื่อ 29 ตุลาคม 2569 จาก https://nginx.org/en/docs/http/ngx_http_fastcgi_module.html

[7] Apache Software Foundation. (ม.ป.ป.). ab Apache HTTP server benchmarking tool. สืบค้นเมื่อ 30 ตุลาคม 2569 จาก https://httpd.apache.org/docs/2.4/programs/ab.html

[8] The PHP Group. (ม.ป.ป.). Description of core php.ini directives. สืบค้นเมื่อ 30 ตุลาคม 2569 จาก https://www.php.net/manual/en/ini.core.php

บรรณานุกรม ต่อ

[9] WordPress.org. (ม.ป.ป.). wp core verify-checksums. สืบค้นเมื่อ 30 ตุลาคม 2569 จาก https://developer.wordpress.org/cli/commands/core/verify-checksums/

[10] Tailscale. (ม.ป.ป.). Connection types. สืบค้นเมื่อ 30 ตุลาคม 2569 จาก https://tailscale.com/docs/reference/connection-types

[11] The PHP Group. (2569). PHP 8 ChangeLog Version 8.5.12. สืบค้นเมื่อ 30 ตุลาคม 2569 จาก https://www.php.net/ChangeLog-8.php#8.5.12

[12] Canonical. (2569). USN-8948-1 PHP vulnerabilities. สืบค้นเมื่อ 30 ตุลาคม 2569 จาก https://ubuntu.com/security/notices/USN-8948-1

[13] Cloudflare. (ม.ป.ป.). security-audit-skill. สืบค้นเมื่อ 30 ตุลาคม 2569 จาก https://github.com/cloudflare/security-audit-skill

เอกสารภายในโครงงาน

บันทึกโครงงาน WordPress บน VPS ที่ปลอดภัยหลายชั้น. (2569). ฉบับวันที่ 29 ตุลาคม 2569. เอกสารภายใน.

ข้อมูลสำหรับทำรายงาน betterson. (2569). ฉบับวันที่ 30 ตุลาคม 2569. เอกสาร PDF 10 หน้า.

คำถามที่อาจารย์อาจถาม งานรอบสอง. (2569). ฉบับวันที่ 30 ตุลาคม 2569. เอกสาร PDF 2 หน้า.

คำถามที่อาจารย์อาจถาม WordPress บน VPS. (2569). ฉบับวันที่ 22 ตุลาคม 2569. เอกสาร PDF 7 หน้า.

คู่มือคำสั่ง betterson. (2569). ฉบับวันที่ 30 ตุลาคม 2569. เอกสาร PDF 8 หน้า.

ผลตรวจความปลอดภัย betterson security-audit. (2569). ผลตรวจ 2 รอบ วันที่ 30 ตุลาคม 2569. เอกสาร PDF 8 หน้า.

Betterson WordPress บน VPS. (2569). สไลด์นำเสนอ PDF 20 หน้า.

สรุปสิ่งที่ต้องแก้ในรายงาน BetterSon. (2569). เอกสาร PDF 3 หน้า.

ภาพหน้าจอการทดสอบและคำอธิบายระบบ BetterSon. (2569). รวบรวมวันที่ 30 ตุลาคม 2569.

ภาคผนวก ก
คู่มือคำสั่งและการทดสอบระบบ

ก.1 การเชื่อมต่อและตรวจข้อมูลระบบ

คู่มือนี้ใช้ประกอบการตรวจระบบ betterson โดยแยกคำสั่งที่รันบนคอมพิวเตอร์ผู้ดูแลกับบนเซิร์ฟเวอร์ คำว่า <ชื่อไฟล์> และ <IP_ผู้ทดสอบ> เป็นค่าที่ต้องแทนก่อนใช้งาน ไม่ใช่ข้อความให้คัดลอกไปรันทั้งชุด

```
ssh -i "D:\NETWORK\id_ed25519" dew@100.91.199.108
```

บนคอมพิวเตอร์ Windows เปิด Tailscale และใช้กุญแจส่วนตัวของตนเอง พาธกุญแจเป็นตัวอย่างตามคู่มือ ห้ามส่ง private key ให้สมาชิกคนอื่น

```
tailscale status
```

ตรวจอุปกรณ์และสถานะใน tailnet การใช้ชื่อโดเมนแทน IP ส่วนตัวจะขึ้นอยู่กับการตั้ง DNS หรือ hosts ของเครื่องนั้น

```
cat /etc/os-release
nginx -v
php -v
mysql --version
```

บนเซิร์ฟเวอร์ ใช้เก็บระบบปฏิบัติการและเวอร์ชันที่ติดตั้ง พร้อมวันเวลาของหลักฐาน

```
sudo ss -tlnp
df -h
free -h
```

ดูพอร์ต TCP ที่เปิดฟัง พื้นที่ดิสก์ และหน่วยความจำ โดย ss ใช้ตรวจด้วยว่า MySQL ไม่ได้ฟังบนทุก interface

```
scp -i "D:\NETWORK\id_ed25519" "dew@100.91.199.108:~/<ชื่อไฟล์>" "D:\NETWORK\"
```

ตัวอย่างดึงไฟล์จาก home ของผู้ดูแลลงคอม ต้องเลือกไฟล์ที่มีสิทธิ์อ่านและตรวจปลายทางก่อนคัดลอก

ภาคผนวก ก คู่มือคำสั่งและการทดสอบระบบ ต่อ

ก.2 ตรวจบริการและเหตุการณ์

```
systemctl is-active nginx php8.5-fpm mysql
```

ตรวจสถานะทั้งสามบริการ ควรเห็น active แต่ละรายการ ชื่อ unit PHP ต้องตรงกับรุ่นที่ติดตั้งจริง

```
sudo systemctl status nginx --no-pager
```

แสดงสถานะละเอียดของ nginx รวมถึงข้อความที่ช่วยตรวจเหตุขัดข้อง

```
sudo tail -n 20 /var/log/nginx/error.log
sudo journalctl -u ssh -n 30 --no-pager
```

ดูข้อผิดพลาดเว็บและเหตุการณ์ SSH โดยไม่ต้องแสดง Log ทั้งหมด

```
sudo tail -f /var/log/nginx/access.log
```

ติดตามคำขอระหว่างทดสอบแบบสด กด Ctrl+C เพื่อหยุดแสดงผล ไม่ได้หยุดบริการเว็บ

```
sudo tail -n 20 /var/log/watchdog.log
sudo tail -n 20 /var/log/integrity-check.log
```

ตรวจบันทึกการกู้คืนและผลตรวจไฟล์ หากไฟล์ไม่มีอยู่ ให้ตรวจตำแหน่งจริงจากสคริปต์

คำสั่งที่โหลดการตั้งค่าใหม่

```
sudo nginx -t && sudo systemctl reload nginx
```

เป็นคำสั่งเปลี่ยนสถานะระบบ ให้ใช้หลังสำรองไฟล์และตรวจ config ผ่านแล้ว การ reload ลดการรบกวนคำขอที่กำลังทำงาน แต่ไม่ทดแทนการตรวจหน้าเว็บหลังเปลี่ยนค่า

```
sudo systemctl restart php8.5-fpm
```

ใช้หลังแก้ค่าของ PHP-FPM หรืออัปเดตแพ็กเกจ ควรตรวจสถานะและหน้าเว็บหลังรีสตาร์ท

ภาคผนวก ก คู่มือคำสั่งและการทดสอบระบบ ต่อ

ก.3 Firewall และการเปลี่ยนกฎ

```
sudo nft list ruleset
sudo nft list chain inet filter input
```

อ่านกฎทั้งหมดหรือ chain input ที่ใช้งานจริง ตรวจพอร์ตเว็บ ชุด IP ไทย และกฎรับจาก tailscale0

```
sudo nft -c -f /etc/nftables.conf
```

ตรวจไฟล์กฎโดยยังไม่ใช้กฎใหม่ การผ่านขั้นตอนนี้ยืนยัน syntax ไม่รับประกันว่าผู้ดูแลจะยังเชื่อมต่อได้

```
sudo grep -c / /etc/nftables.d/th.nft
```

คำสั่งในคู่มือใช้นับบรรทัดที่มีเครื่องหมาย / จึงเป็นค่าตรวจคร่าว ๆ ไม่ใช่การตรวจความถูกต้องของทุก CIDR หรือประเทศต้นทาง

ก่อนเปลี่ยนกฎให้สำรองไฟล์ เปิด session ผู้ดูแลสำรอง และเตรียมช่องทางกู้คืนจาก AWS การรีบูตไม่ทำให้กฎที่บันทึกไว้โหลดตอนบูตหายไปเอง ต้องตรวจทั้ง Security Group และ Firewall ในเครื่อง

```
sudo nft -f /etc/nftables.conf
```

โหลดกฎใหม่ซึ่งอาจตัดการเชื่อมต่อ หากไฟล์มี flush ruleset จะล้างกฎของบริการอื่นด้วย ให้ตรวจผลกระทบก่อนใช้

```
sudo systemctl restart fail2ban tailscaled
```

คู่มือระบุว่าใช้คืนกฎของสองบริการหลังโหลด ruleset ที่ล้างกฎทั้งหมด คำสั่งนี้อาจกระทบช่องทาง SSH ผ่าน Tailscale จึงต้องมีช่องทางกู้คืนและตรวจการเชื่อมต่อซ้ำ

```
sudo /usr/local/sbin/update-th-ip.sh
```

เรียกสคริปต์อัปเดตรายการประเทศทันที เป็นคำสั่งเปลี่ยนกฎ ควรตรวจสคริปต์และ Log ก่อนใช้

ภาคผนวก ก คู่มือคำสั่งและการทดสอบระบบ ต่อ

ก.4 fail2ban และการปลดแบนผู้ทดสอบ

```
sudo fail2ban-client status
sudo fail2ban-client status honeypot
sudo fail2ban-client status nginx-forbidden
```

ดูรายชื่อ jail และสถานะการแบนตามแต่ละ jail เก็บผลก่อนและหลังทดสอบพร้อมเวลา

```
sudo fail2ban-client get honeypot maxretry
sudo fail2ban-client get honeypot bantime
sudo fail2ban-client get nginx-forbidden maxretry
```

ตรวจเกณฑ์ที่มีผลจริง คู่มือระบุ Honeypot maxretry 1 และแบน 24 ชั่วโมง ส่วน nginx-forbidden นับคำตอบ 403 ซ้ำ

```
sudo tail -n 5 /var/log/nginx/honeypot.log
```

ดูเหตุการณ์เส้นทางล่อล่าสุด ข้อมูลอุปกรณ์จาก User-Agent ไม่ใช่หลักฐานยืนยันบุคคลหรืออุปกรณ์อย่างแน่นอน

```
sudo fail2ban-client set honeypot unbanip <IP_ผู้ทดสอบ>
```

ปลดแบนเฉพาะ IP ที่ยืนยันว่าเป็นผู้ทดสอบ หากติด jail อื่นด้วยให้ตรวจแล้วปลดแบนใน jail นั้นตามความจำเป็น

ไม่ควรใช้ unban --all เป็นขั้นตอนประจำหลังสาธิต เพราะจะยกเลิกการแบนผู้ที่ไม่เกี่ยวข้องทั้งหมด ให้ตรวจ IP สาธารณะของผู้ทดสอบและเลือกปลดเฉพาะรายการ

เส้นทาง Honeypot ตามคู่มือคือ /phpmyadmin, /pma, /wp-admin-backup, /old-admin, /backup.zip และ /db.sql การเปิดหนึ่งครั้งอาจทำให้ IP ถูกแบน 24 ชั่วโมง ส่วน /.env ใช้ตรวจการตอบ 403 และการทำงานของ nginx-forbidden จึงไม่ควรทดลองจาก IP สาธารณะที่ผู้ใช้อื่นใช้ร่วมกัน

ภาคผนวก ก คู่มือคำสั่งและการทดสอบระบบ ต่อ

ก.5 WordPress การตรวจไฟล์และสำรองข้อมูล

```
sudo -u www-data wp core version --path=/var/www/betterson
sudo -u www-data wp plugin list --path=/var/www/betterson
```

ดูเวอร์ชัน WordPress และรายการปลั๊กอิน ในการใช้งานจริงต้องเลือกบัญชีที่ได้รับสิทธิ์ตามนโยบายเครื่อง

```
sudo -u www-data wp core verify-checksums --path=/var/www/betterson
```

ตรวจไฟล์ core กับ checksum ตามรุ่นที่ติดตั้ง ไม่ครอบคลุมฐานข้อมูล สื่อ และไฟล์ทุกประเภท

```
sudo /usr/local/sbin/integrity-check.sh
```

เรียกตรวจตามสคริปต์ทันที แล้วตรวจ Log และ Telegram หากมีการเปลี่ยนแปลงที่ตรวจพบ

```
sudo grep -n "WP_DEBUG" /var/www/betterson/wp-config.php
```

ตรวจค่าที่ประกาศไว้ โดยพิจารณาบริบทของบรรทัดและค่าที่มีผลจริง ไม่แสดงไฟล์ทั้งหมดซึ่งอาจมีรหัสฐานข้อมูล

```
sudo /usr/local/sbin/backup-wordpress.sh
```

สั่งสำรองทันทีตามสคริปต์ ตรวจว่ามีไฟล์ใหม่ สำรองฐานข้อมูลสำเร็จ และมีสำเนานอกเครื่อง การมีไฟล์สำรองยังต้องทดสอบกู้คืนแยก

ข้อควรตรวจเรื่องสิทธิ์ไฟล์

chmod 640 หมายถึงเจ้าของอ่านและเขียนได้ กลุ่มอ่านได้ และผู้ใช้อื่นไม่มีสิทธิ์ ไม่ใช่อ่านได้เฉพาะเจ้าของ ส่วน chmod 600 จำกัดอ่านและเขียนไว้ที่เจ้าของเท่านั้น การเป็น root หรือการมีสิทธิ์พิเศษยังเข้าถึงได้ตามระบบสิทธิ์

ไม่ควรใช้ chown -R หรือเปลี่ยนสิทธิ์ทุกไฟล์เป็นกิจวัตร เพราะอาจทับสิทธิ์พิเศษของ wp-config.php และเปิดให้บัญชีเว็บเขียนโค้ดเกินจำเป็น ต้องตรวจเจ้าของ กลุ่ม และโฟลเดอร์ที่ต้องเขียนก่อนเปลี่ยน

ภาคผนวก ก คู่มือคำสั่งและการทดสอบระบบ ต่อ

ก.6 แผนทดสอบและหลักฐานประกอบ

แยกเครื่องผู้ดูแลที่ใช้ Tailscale ออกจากเครื่องทดสอบสาธารณะ ใช้เครือข่ายทดสอบที่ผู้จัดทำควบคุมได้และตรวจ IP จริงก่อนทดลอง การต่อ Tailscale เพียงอย่างเดียวไม่ได้ทำให้ทุกคำขอเว็บออกผ่าน tailscale0 เส้นทางขึ้นอยู่กับ DNS hosts และการกำหนดเครือข่าย

```
curl -I https://betterson.duckdns.org/
sudo certbot certificates
sudo certbot renew --dry-run
```

ตรวจ Header ใบรับรอง และการต่ออายุจำลอง การใช้ curl -k ข้ามการตรวจใบรับรองจึงไม่ใช้เป็นหลักฐานยืนยัน TLS

```
curl -I --resolve betterson.duckdns.org:443:127.0.0.1 https://betterson.duckdns.org/
```

บนเซิร์ฟเวอร์ ส่งไป loopback โดยยังใช้ชื่อโดเมนสำหรับ TLS แล้วเก็บ X-Cache เพื่อดู MISS HIT หรือ BYPASS

```
ab -n 200 -c 10 -H "Host: betterson.duckdns.org" https://127.0.0.1/
```

เป็นการสร้างภาระงานตามคู่มือบนเซิร์ฟเวอร์ของกลุ่ม เก็บผลฉบับเต็ม ตรวจ status และเนื้อหาคำตอบ ไม่ทดสอบขณะใช้งานที่สำคัญ

การหยุด nginx หรือส่ง KILL เป็นการเปลี่ยนสถานะบริการเพื่อสาธิต ให้กำหนดช่วงทดสอบและเตรียมคำสั่งกู้คืน เก็บสถานะบริการ Log กับ Telegram ก่อนและหลัง ไม่รันคำสั่งหยุดบริการเป็นส่วนหนึ่งของชุดตรวจสถานะทั่วไป

ภาคผนวก ก คู่มือคำสั่งและการทดสอบระบบ ต่อ

ก.7 การตรวจยืนยันหลัง audit

ชุดคำสั่งนี้ใช้ดูค่าหรือทดสอบ syntax เพื่อประกอบหลักฐาน เลือกเฉพาะรายการที่ต้องการ ไม่รวมคำสั่งแก้ไฟล์ ล้าง cache หรือรีสตาร์ทบริการตามคำแนะนำในเอกสารต้นทาง

```
sudo fail2ban-client get honeypot ignoreip
sudo fail2ban-client get nginx-forbidden ignoreip
```

เก็บผลของแต่ละ jail เพื่อยืนยันข้อยกเว้นจริง อย่าตรวจเฉพาะ sshd

```
sudo nginx -t
sudo head -n 35 /etc/nginx/snippets/hardening.conf
```

ตรวจ syntax และอ่านลำดับ Honeypot ก่อนกฎ .sql รวมถึงขอบเขต regex โดยไม่ส่งคำขอไปยังลิงก์กับดัก

```
sudo bash -n /usr/local/sbin/update-th-ip.sh
sudo nft -c -f /etc/nftables.conf
```

ตรวจ syntax ของสคริปต์และกฎ คำสั่งนี้ไม่ใช่การพิสูจน์ว่าข้อมูลภายนอกปลอดภัยหรือโหลดกฎแล้ว

```
sudo -u www-data wp plugin list --status=must-use --path=/var/www/betterson
```

ตรวจรายการ mu-plugin ที่เพิ่มขึ้น แยกจากปลั๊กอินปกติและขอบเขต checksum เดิม

```
sudo php -l /var/www/betterson/wp-content/mu-plugins/hide-users.php
```

ตรวจ syntax PHP ไม่ใช่ผลทดสอบสิทธิ์หรือการเปิดเผยข้อมูลทุกช่องทาง

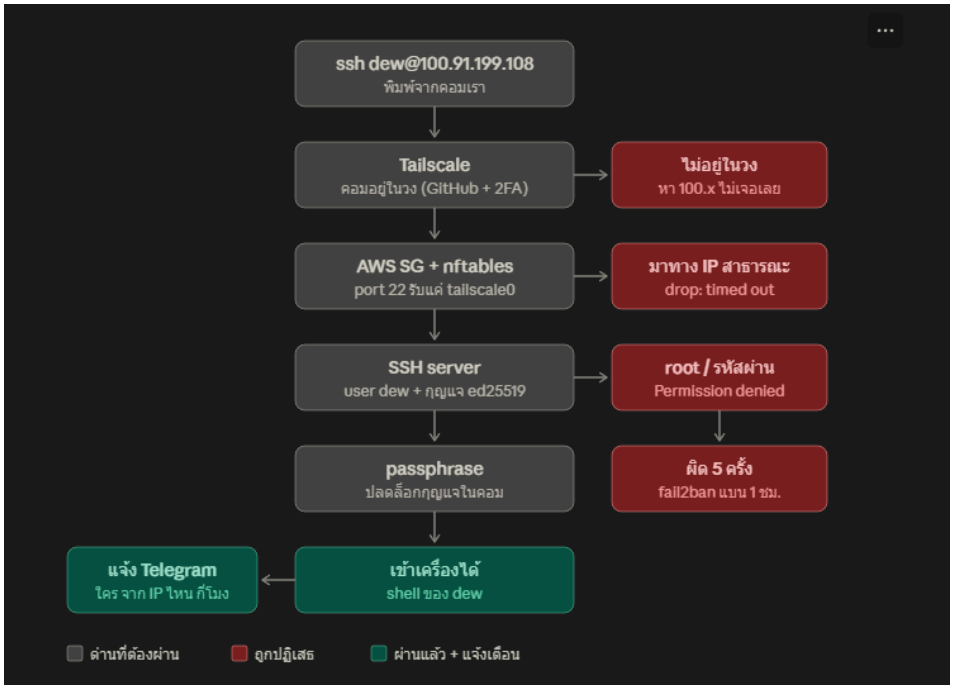
หลักฐาน N1 ควรตรวจชื่อที่แสดงเทียบกับชื่อเข้าสู่ระบบ โดยเก็บผลไว้ภายในและปกปิดชื่อที่ไม่จำเป็นก่อนแนบรายงาน ส่วน R1–R2 ต้องมีผลทดสอบหลังแก้ และ R3 ต้องมีบันทึกการกู้คืน ไม่ถือว่าผลตรวจ syntax ผ่านเท่ากับปิดข้อค้นพบแล้ว

ภาคผนวก ข
รายการหลักฐานประกอบ

ภาคผนวกนี้สรุปหลักฐานการทดสอบที่แสดงในรายงาน โดยระบุหมวดหลักฐานและหมายเลขภาพสำหรับค้นหา

ลำดับ	หลักฐานที่แนบ
ข.1	ผล SSH ผ่าน IP สาธารณะ ภาพที่ จ.1 และ จ.13
ข.2	ผล FastCGI cache และ ApacheBench ภาพที่ 4.1
ข.3	ผลปฏิเสธไฟล์ตั้งค่า REST users และ rate limit ภาพที่ จ.10–จ.12
ข.4	Security Dashboard และ Telegram ภาพที่ จ.3–จ.6
ข.5	ข้อความแจ้ง DOWN และ UP พร้อมเวลา ภาพที่ จ.3

ภาคผนวก ค
ภาพประกอบเส้นทางการสื่อสาร

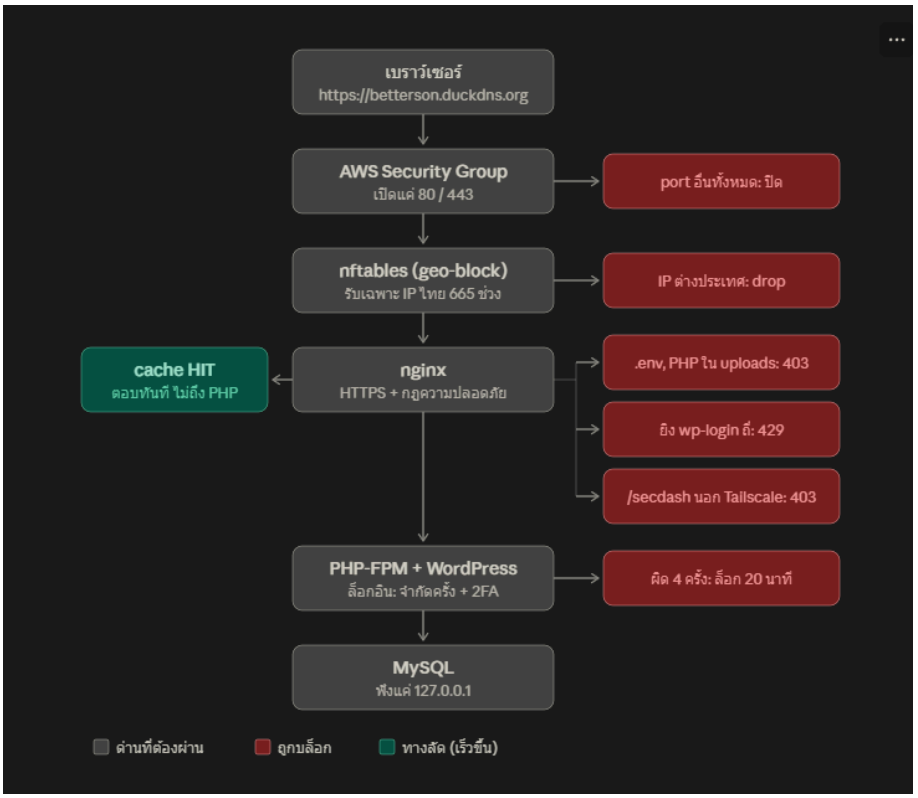


ภาพที่ ค.1 แผนผังการเข้า SSH ผ่าน Tailscale

ที่มา ภาพประกอบของผู้จัดทำ

คำอธิบายเพิ่มเติม passphrase ใช้ปลดล็อก private key ที่เครื่องผู้ดูแล และอาจถูกจัดการผ่าน SSH agent ไม่ใช่ด่านตรวจรหัสแยกบนเซิร์ฟเวอร์ ส่วน Security Group ปิดการรับ TCP 22 สาธารณะ ขณะที่ nftables ตรวจ interface tailscale0 หลังถอดอุโมงค์แล้ว ไม่ใช่ Security Group มองเห็น interface นี้

ภาคผนวก ค ภาพประกอบเส้นทางการสื่อสาร ต่อ

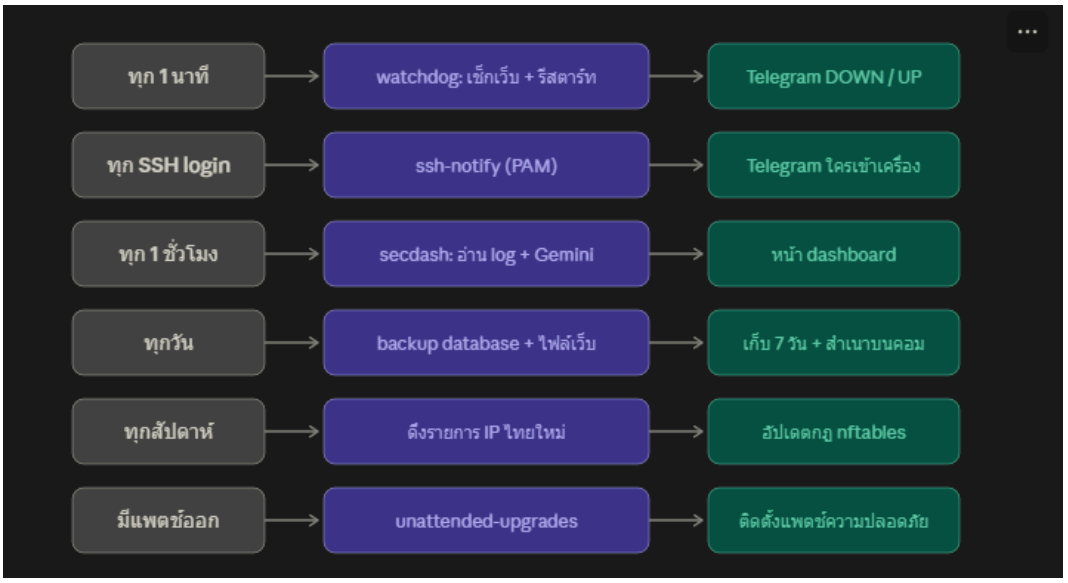


ภาพที่ ค.2 แผนผังเส้นทางเว็บไซต์และ cache

ที่มา ภาพประกอบของผู้จัดทำ

ภาพแสดงกฎหลักก่อนเพิ่ม Honeypot โดย /.env ตอบ 403 ของกลุ่มระบบ ส่วนกับดักหกเส้นทางในหัวข้อ 3.11 ตอบ 404 แล้วใช้ fail2ban แบนภายหลัง nginx ติดต่อ PHP-FPM ผ่าน FastCGI เมื่อคำขอไม่เข้าเงื่อนไข cache และการเข้า WordPress ยังใช้บัญชีพร้อม TOTP จำนวน IP ไทย 665 ช่วงในภาพเป็นค่าเดิม ผล audit หลังอัปเดตระบุ 667 ช่วง จึงไม่ใช้ภาพนี้ยืนยันจำนวนล่าสุด

ภาคผนวก ค ภาพประกอบเส้นทางการสื่อสาร ต่อ



ภาพที่ ค.3 แผนผังงานเบื้องหลังตามรอบเวลา

ที่มา ภาพประกอบของผู้จัดทำ

นอกจากงานในภาพ กลุ่มตั้ง integrity-check ทุกวันเวลา 10:17 น. (เวลาไทย) เพื่อตรวจ checksum และแจ้ง Telegram ส่วน unattended-upgrades ทำงานตามรอบที่กำหนดเพื่ออัปเดตแพตช์ความปลอดภัย

การตรวจด้วย watchdog ทุกหนึ่งนาทีเป็นช่วงตรวจที่กำหนด ไม่ใช่การรับประกันว่าระบบจะกู้คืนได้ภายในหนึ่งนาทีเสมอ ควรติดตาม Log การรีสตาร์ทและตรวจจากภายนอก เพื่อแยกความขัดข้องของเครื่อง บริการ และเครือข่าย

ภาคผนวก ง
แนวคำตอบประกอบการนำเสนอ

เหตุใดเซิร์ฟเวอร์อยู่ซิดนีย์ แต่ให้เข้าเฉพาะไทย

กฎประเทศพิจารณา IP ต้นทางของผู้เชื่อมต่อ ส่วนที่ตั้งเซิร์ฟเวอร์เป็นปลายทาง คนละเงื่อนไขกัน และต้องทดสอบต่างประเทศจริงก่อนยืนยันผล

เหตุใดใช้ Tailscale แทนการอนุญาต IP บ้าน

IP บ้านเปลี่ยนได้ Tailscale แยกช่องทางผู้ดูแลออกจากอินเทอร์เน็ตสาธารณะ แต่ยังต้องมีสิทธิ์ใน tailnet และกุญแจ OpenSSH การเชื่อมต่ออาจเป็น direct หรือ relay ตามเครือข่าย [10]

cache เร็วขึ้นเท่าใดและวัดอย่างไร

รอบที่บันทึกใช้ ab -n 200 -c 10 ได้ 548.30 เทียบ 19.96 คำขอต่อวินาที หรือ 27.47 เท่า เป็น throughput ภายในเครื่อง ไม่รวมเวลาจากอินเทอร์เน็ต และยังต้องทดสอบซ้ำ

Honeypot ต่างจากกฎตอบ 403 อย่างไร

เส้นทางล่อส่งเหตุการณ์ให้ fail2ban เพิ่มกฎแบน IP ที่พอร์ตเว็บ ส่วนกฎตอบ 403 ปฏิเสธคำขอนั้นโดยตรง การแบนมีความหน่วงและอาจแบนคนปกติหรือผู้ใช้ NAT ร่วมกัน

กุญแจ SSH กับ passphrase อยู่ที่ใด

public key อยู่ใน authorized_keys บนเซิร์ฟเวอร์ private key อยู่เครื่องผู้ดูแล passphrase ป้องกันไฟล์ private key และไม่ใช่รหัสผ่านบัญชีเซิร์ฟเวอร์

ภาคผนวก ง แนวคำตอบประกอบการนำเสนอ ต่อ

ตัวเลข Log บอกว่ามีผู้โจมตีกี่คนได้หรือไม่

ไม่ได้ 109 IP ไม่เท่ากับจำนวนคน และ 403/404 ไม่ได้แปลว่าโจมตีเสมอ ยังมีการทดสอบในกลุ่มกับ Heartbeat อีกทั้งทราฟฟิกที่ถูกทิ้งก่อน nginx ไม่อยู่ใน access log

Failed requests เป็นศูนย์แปลว่าทุกคำขอเป็น 200 หรือไม่

ยังสรุปไม่ได้ ต้องดู Non-2xx responses สถานะ เนื้อหา และขนาดคำตอบด้วย ภาพที่มีกรองมาเฉพาะบางบรรทัด จึงไม่ทดแทนผลฉบับเต็ม

checksum ผ่านแปลว่าเว็บปลอดภัยทั้งหมดหรือไม่

ไม่ใช่ แสดงเฉพาะไฟล์ที่เปรียบเทียบตรงกับค่าอ้างอิงตามรุ่นและขอบเขตคำสั่ง ฐานข้อมูล ไฟล์ uploads ธีม mu-plugins และปลั๊กอินที่ไม่มี checksum ต้องตรวจด้วยแนวทางอื่น

หากกฎ Firewall ผิดจนเข้าไม่ได้ควรทำอย่างไร

ใช้ช่องทางกู้คืนที่เตรียมไว้และตรวจ Security Group กับกฎในเครื่อง การรีบูตไม่รับประกันว่าจะล้างกฎเมื่อมีการโหลดกฎตอนบูต จึงต้องมีแผนย้อนกลับและทดสอบจาก session สำรอง

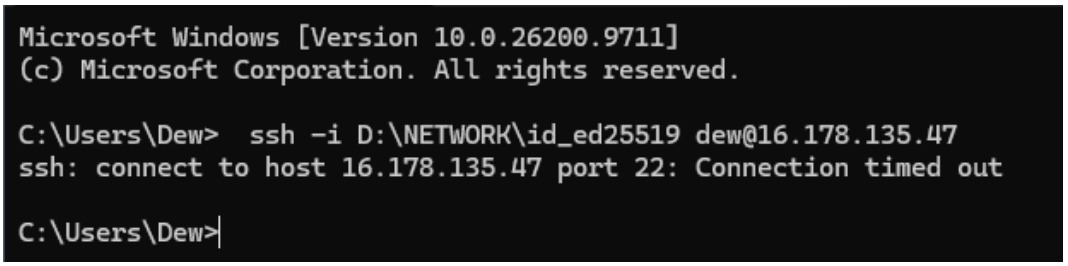
งานใดยังไม่ครบ

กลุ่มทดสอบ VPN ต่างประเทศแล้วเข้าเว็บไม่ได้ ส่วนงานพัฒนาต่อคือ IPv6 การกู้คืนสำรอง การแก้ backup codes ของ 2FA การตั้ง CSP และการติดตาม N1 กับ R1–R3

ภาคผนวก จ

ภาพหลักฐานประกอบการทดสอบ

จ.1 การเข้าถึง SSH และการแบนจากกับดัก



ภาพที่ จ.1 SSH ผ่าน IP สาธารณะหมดเวลารอ

ที่มา สไลด์ PDF หน้า 4

กลุ่มใช้กุญแจ SSH เชื่อมต่อ dew@16.178.135.47 แล้วได้รับ Connection timed out แสดงผลการปิดช่องทาง SSH สาธารณะจากเครื่องทดสอบ



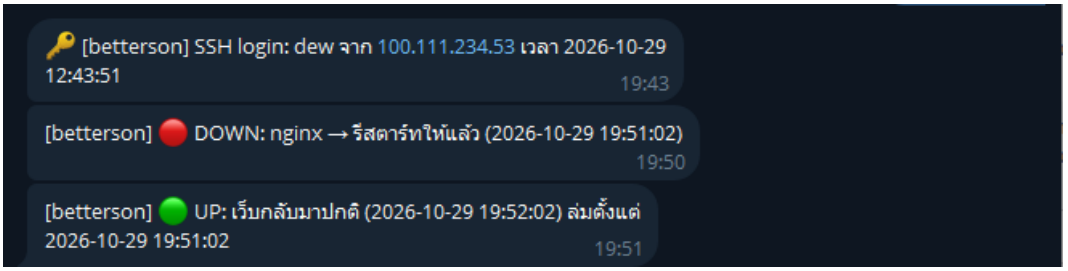
ภาพที่ จ.2 สถานะ jail honeypot ที่แบนอยู่ 2 IP

ที่มา สไลด์ PDF หน้า 9

กลุ่มทดสอบเปิด /old-admin จากผู้ร่วมทดสอบสองคน แล้วพบ Currently banned: 2 และ Total banned: 2 ดังภาพ โดยปิดเลข IP บางส่วนก่อนนำเสนอ

ภาคผนวก จ ภาพหลักฐานประกอบการทดสอบ ต่อ

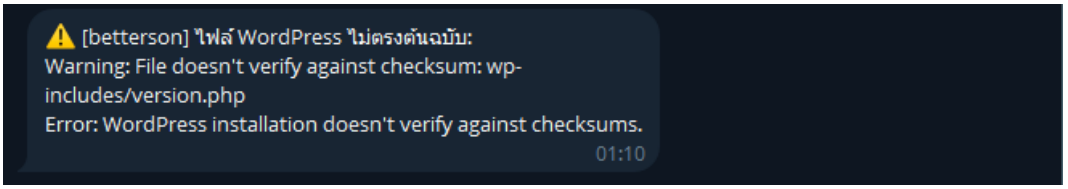
จ.2 การแจ้งเตือนและการตรวจความเปลี่ยนแปลง



ภาพที่ จ.3 ข้อความ Telegram ของ SSH และ DOWN กับ UP

ที่มา สไลด์ PDF หน้า 11

กลุ่มได้รับ Telegram เมื่อมี SSH login และเมื่อ nginx เปลี่ยนสถานะ DOWN กับ UP ข้อความ DOWN ระบุ 19:51:02 และ UP ระบุ 19:52:02 รวมช่วงขัดข้องหนึ่งนาที



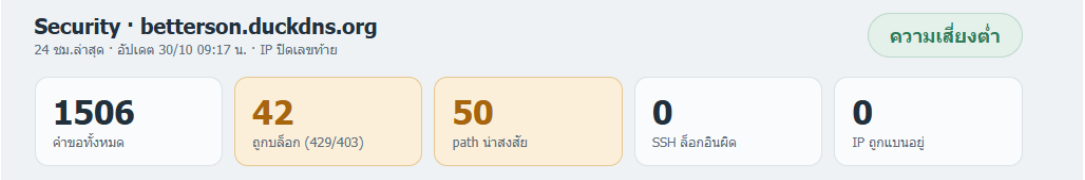
ภาพที่ จ.4 การแจ้ง checksum ไม่ตรงสำหรับ version.php

ที่มา สไลด์ PDF หน้า 11

กลุ่มแก้ wp-includes/version.php หนึ่งบรรทัดแล้วเรียกตรวจ checksum ระบบพบไฟล์ต่างจากต้นฉบับและแจ้ง Telegram ตามภาพ

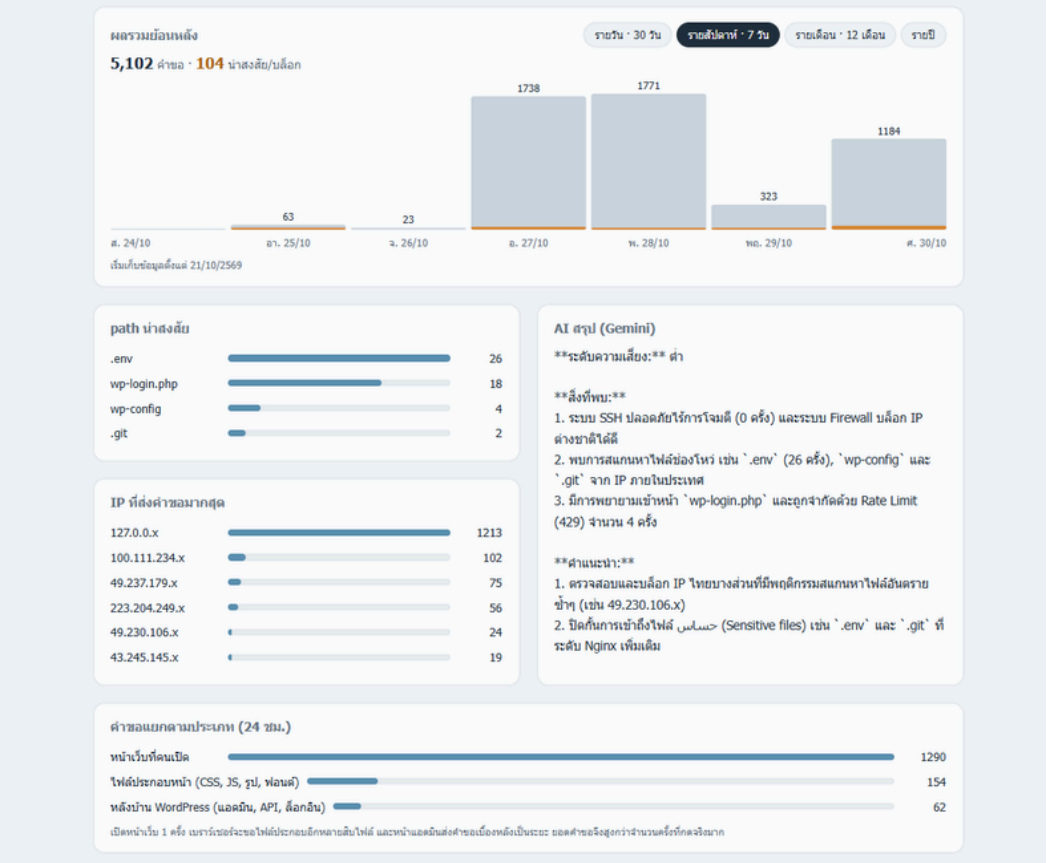
ภาคผนวก จ ภาพหลักฐานประกอบการทดสอบ ต่อ

จ.3 หน้า Security Dashboard



ภาพที่ จ.5 สรุป Dashboard ในช่วง 24 ชั่วโมง

ที่มา สไลด์ PDF หน้า 13



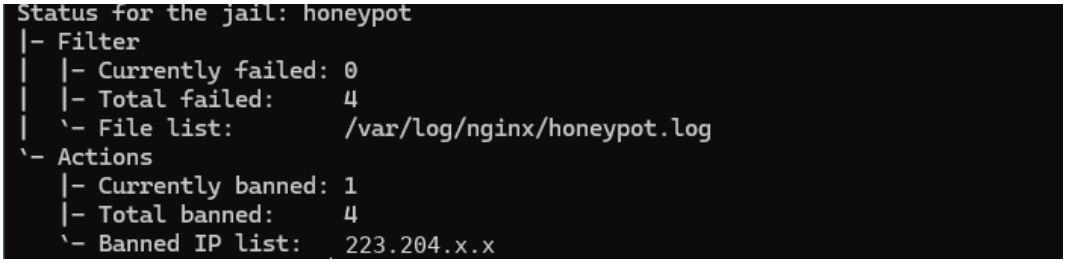
ภาพที่ จ.6 กราฟและคำสรุปของ Dashboard

ที่มา สไลด์ PDF หน้า 13

ภาพสรุป 24 ชั่วโมงระบุ 1,506 คำขอ ส่วนกราฟย้อนหลัง 7 วันระบุ 5,102 คำขอ เป็นคนละช่วงกับ nginx Log 5,123 จึงไม่รวมยอดหรือเทียบกันโดยไม่ตรวจนิยามและช่วงเวลา คำสรุป AI ใช้ประกอบการพิจารณา

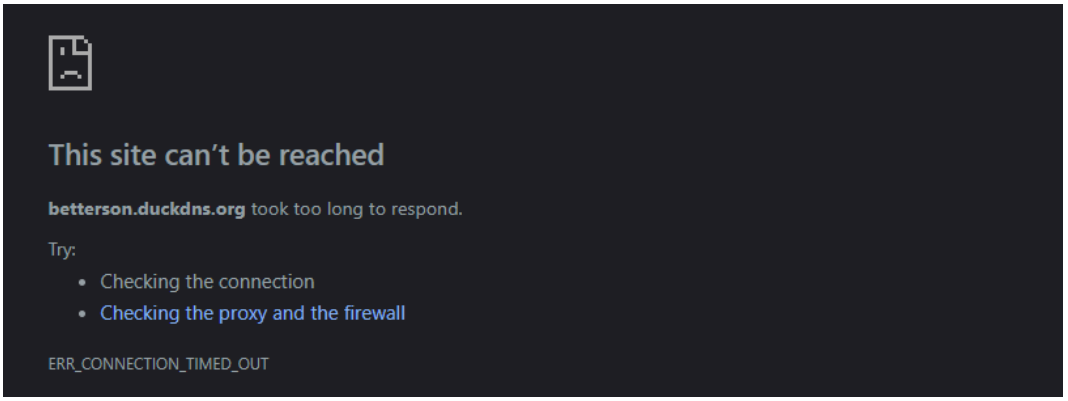
ภาคผนวก จ ภาพหลักฐานประกอบการทดสอบ ต่อ

จ.4 ผลการทดสอบการแบนอีกช่วงเวลา



ภาพที่ จ.7 สถานะ Honeypot ในรอบทดสอบภายนอก

ที่มา สไลด์ PDF หน้า 16 ซึ่งมีเลขท้ายสไลด์พิมพ์เป็น 15



ภาพที่ จ.8 เบราว์เซอร์หมดเวลารอหลังการทดสอบ

ที่มา สไลด์ PDF หน้า 16

การทดสอบ Honeypot อีกช่วงให้ผล Currently banned: 1 และ Total banned: 4 จากนั้นเครื่องทดสอบเปิดหน้าเว็บไม่ได้และแสดง ERR_CONNECTION_TIMED_OUT

ภาพนี้แสดงผลหลังการแบน Honeypot ส่วนผลทดสอบ VPN ต่างประเทศสรุปแยกไว้ในหัวข้อ 4.1

ภาคผนวก จ ภาพหลักฐานประกอบการทดสอบ ต่อ

จ.5 ผลสรุป Log จาก Terminal



ภาพที่ จ.9 ผลสรุป nginx Log และการนับสถานะ

ที่มา สไลด์ PDF หน้า 14

กลุ่มสรุป nginx Log ได้ 5,123 คำขอจาก 109 IP ภาพแสดงรายการ HTTP status หลัก และจำนวนคำขอที่ถูกจำกัดด้วย 429 แยกไว้ด้านล่าง

ภาพคำสั่ง curl ในสไลด์หน้า 8 เป็นผลก่อนเพิ่ม hardening ส่วนภาพที่ จ.10–จ.11 แสดงตัวอย่างผลปฏิเสธคำขอหลังปรับกฎ กลุ่มทดสอบ /wp-json/wp/v2/users และ /?author=1 แล้วได้ 403 ทั้งสองเส้นทาง

ภาคผนวก จ ภาพหลักฐานประกอบการทดสอบ ต่อ

จ.6 ภาพผลการตอบ 403 และ 429



ภาพที่ จ.10 wp-config.php ตอบ 403 Forbidden

ภาพยืนยันการปฏิเสธการเรียก /wp-config.php โดยตรง ไม่ใช่ผลของเส้นทางอื่น



ภาพที่ จ.11 ตัวอย่าง REST users ตอบ 403 Forbidden

ทั้ง /wp-json/wp/v2/users และ /?author=1 ตอบ 403 Forbidden โดยภาพนี้แสดงตัวอย่างผลของ REST users



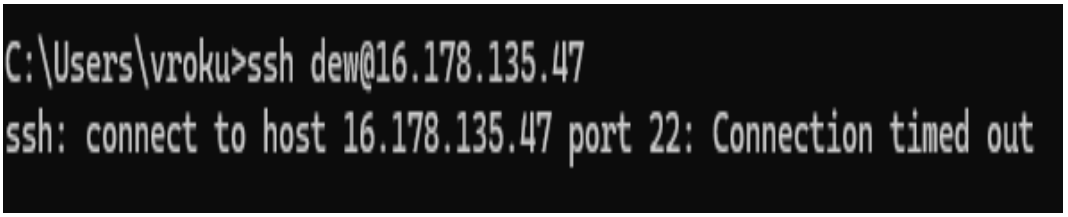
ภาพที่ จ.12 wp-login.php ตอบ 429 Too Many Requests

กลุ่มส่งคำขอหน้าเข้าสู่ระบบต่อเนื่องจน nginx ตอบ 429 ตามกฎ rate limit ที่อัตราพื้นฐาน 10 ครั้งต่อนาทีต่อ IP และ burst 5

ที่มา ภาพหน้าจอจากผู้จัดทำ วันที่ 30 ตุลาคม 2569

ภาคผนวก จ ภาพหลักฐานประกอบการทดสอบ ต่อ

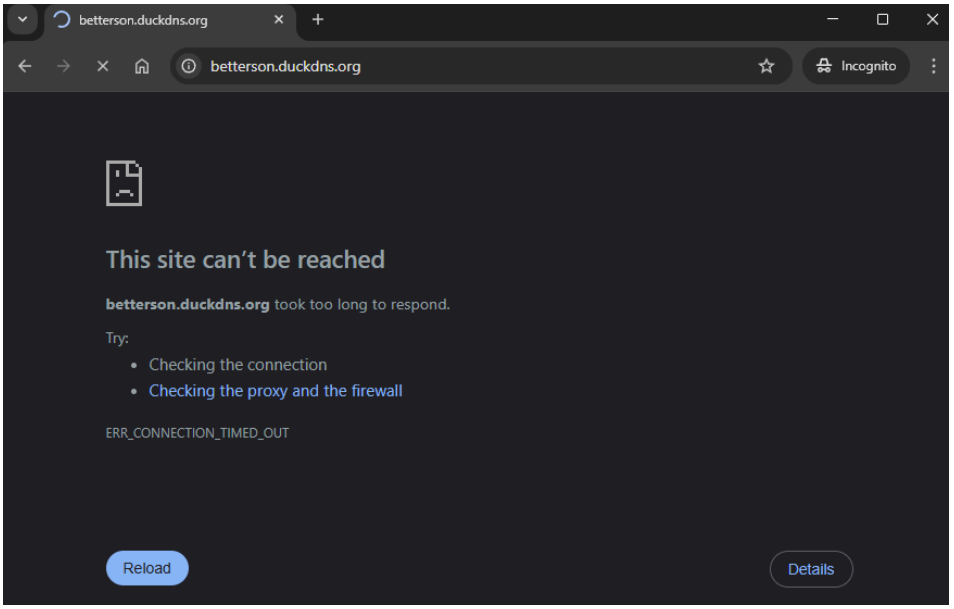
จ.7 ภาพ SSH และเว็บที่หมดเวลารอ



ภาพที่ จ.13 SSH ผ่าน IP สาธารณะหมดเวลารอ

ที่มา ภาพหน้าจอเพิ่มเติมจากผู้จัดทำ วันที่ 30 ตุลาคม 2569

กลุ่มเชื่อมต่อ dew@16.178.135.47 แล้วได้รับ Connection timed out ตามภาพ เป็นผลการทดสอบช่องทาง SSH ผ่าน IP สาธารณะ



ภาพที่ จ.14 เว็บหมดเวลารอหลังลำดับทดสอบที่แจ้ง

ที่มา ภาพหน้าจอเพิ่มเติมจากผู้จัดทำ วันที่ 30 ตุลาคม 2569

กลุ่มเปิด /?author=1 และ /wp-json/wp/v2/users ซ้ำ 5 รอบ แล้วเข้า /phpmyadmin จากนั้นหน้าเว็บหมดเวลารอ ภาพนี้แสดงผลหลังลำดับการทดสอบดังกล่าว